

บทที่ 2

ทฤษฎีที่เกี่ยวข้อง

2.1 บทนำ

ในการที่จะสร้างระบบต้นแบบซึ่งเป็นระบบตอบสนองต่อผู้ละเมิดความปลอดภัย การศึกษาทฤษฎีที่เกี่ยวข้องเป็นเรื่องที่สำคัญเป็นอย่างยิ่ง โดยเฉพาะทฤษฎีในเรื่องของขั้นตอน แนวความคิดในการตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัย ทฤษฎีการตรวจจับบุกรุกหรือผู้ละเมิดความปลอดภัย และการใช้โปรแกรมต่างๆ ในการเก็บข้อมูลเพื่อนำไปใช้ในการวิเคราะห์ต่อไป

2.2 ทฤษฎีการตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัย (Incident Response)

2.2.1 นิยามและความหมาย

Incident หมายถึง เหตุการณ์ที่เป็นภัยคุกคามต่อความปลอดภัยของระบบคอมพิวเตอร์ และระบบเครือข่าย เช่น คอมพิวเตอร์หรือระบบเครือข่ายหยุดทำงาน การสั่งให้โปรแกรมที่ประสงค์ร้าย (malicious code) ทำงาน การใช้งาน Account ของผู้อื่นโดยไม่ได้รับอนุญาต

ทั้งนี้เหตุการณ์ที่เป็นภัยคุกคามต่อความปลอดภัยของระบบคอมพิวเตอร์และระบบเครือข่าย จะไม่รวมถึงเหตุการณ์ที่เป็นภัยธรรมชาติ เช่น น้ำท่วม ไฟไหม้ ไฟตก เป็นต้น

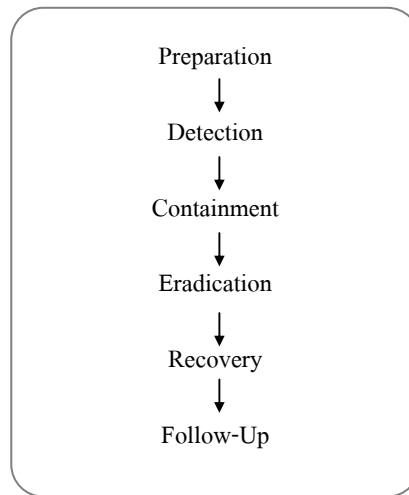
Incident Response หมายถึง การดำเนินการกับเหตุการณ์ละเมิดความปลอดภัยที่เกิดขึ้น การดำเนินการนี้มีจุดประสงค์เพื่อกำจัดหรือลดผลกระทบที่อาจเกิดขึ้นกับระบบ

2.2.2 เป้าหมายหรือวัตถุประสงค์ของการรับมือและการตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัย

1. เพื่อหาข้อมูลว่าเหตุการณ์นั้นเกิดขึ้นได้อย่างไร
2. หาวิธีป้องกันไม่ให้เกิดเหตุการณ์ประเภทนี้อีก
3. ป้องกันไม่ให้เกิดเหตุการณ์ลุกลามจนนำมาสู่ความเสียหายต่อระบบ
4. ประเมินผลกระทบและความเสียหายจากเหตุการณ์
5. ฟื้นฟูระบบจากเหตุการณ์
6. แก้ไขนโยบายและระเบียบปฏิบัติให้เหมาะสมขึ้น
7. ค้นหาผู้ก่อเหตุ (หากเหมาะสมและเป็นไปได้)

2.2.3 การตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัย

แนวคิดในการตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัย 6 ขั้นตอนดังนี้คือ



รูปที่ 2.1 ขั้นตอนการตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัย

2.2.4 ขั้นตอนที่ 1 การเตรียมการ (Preparation)

ขั้นตอนการเตรียมการเป็นการเตรียมความพร้อมเพื่อที่จะรับมือกับเหตุการณ์ที่จะเกิดขึ้น ขั้นตอนนี้ถือได้ว่าเป็นขั้นตอนที่สำคัญ เป็นขั้นตอนที่มีความซับซ้อนและต้องใช้เวลาในการเตรียมสิ่งจำเป็น ในขั้นตอนการเตรียมการประกอบด้วย 4 กระบวนการพื้นฐานดังนี้คือ

- 1) ติดตั้งระบบป้องกันและควบคุมต่อเหตุการณ์ที่อาจเกิดขึ้น
- 2) เตรียมแผนการปฏิบัติที่จะดำเนินการกับเหตุการณ์ที่จะเกิดขึ้นอย่างมีประสิทธิภาพ

แผนการปฏิบัติสำหรับการดำเนินการกับเหตุการณ์ละเมิดความปลอดภัยควรมีวิธีการอย่างน้อยดังต่อไปนี้

- วางแผนการและระบุขั้นตอนการดำเนินการต่อเหตุการณ์ละเมิดความปลอดภัย ภายใต้สภาพแวดล้อมที่กำหนด
- บุคคลที่ควรจะต้องแจ้งหรือติดต่อเมื่อเกิดเหตุการณ์ละเมิดความปลอดภัยขึ้น
- ระบุประเภทของข้อมูลที่สามารถเปิดเผยและข้อมูลที่ไม่สามารถเปิดเผยต่อบุคคลภายนอกได้
- จัดลำดับความสำคัญของขั้นตอนการตอบสนองเมื่อเกิดการละเมิดความปลอดภัย
- ระบุหน้าที่และบทบาทของแต่ละบุคคลที่เป็นส่วนหนึ่งของการตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัย

- จัดทำเอกสารที่ระบุถึงระดับความเสี่ยงที่สามารถยอมรับได้ และเอกสารนโยบายด้านความปลอดภัยขององค์กรเพื่อใช้เป็นแนวทางในการดำเนินการตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัย

3) จัดหาทรัพยากรทุกอย่างที่จำเป็นทั้งทรัพยากรทางด้านวัตถุ และทรัพยากรบุคคล

ทรัพยากรในที่นี้เป็นทุกสิ่งที่จะต้องใช้ในการสำเร็จของการตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัยไม่ว่าจะเป็นฮาร์ดแวร์ ซอฟต์แวร์ หรือแม้แต่การฝึกอบรม

สำหรับซอฟต์แวร์ที่จำเป็นต้องใช้ตัวอย่างเช่น ซอฟต์แวร์ตรวจจับบุกรุก (Intrusion detection software) เครื่องมือในการทำรีเวิร์สเอ็นจิเนียริง (Reverse engineering tool) ซอฟต์แวร์สำหรับการสืบค้นและวิเคราะห์ (Forensic analysis software) ซอฟต์แวร์ระบบฐานข้อมูล (Database server software) เป็นต้น

4) จัดเตรียมโครงสร้างพื้นฐานที่สนับสนุนการตอบสนองต่อเหตุการณ์ที่เกิดขึ้น

การที่จะตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัยได้อย่างเสร็จสมบูรณ์จะต้องมีการจัดเตรียมโครงสร้างพื้นฐานขององค์กรที่สนับสนุนกระบวนการ โดยโครงสร้างพื้นฐานเหล่านั้นจะต้องมีความเป็นเอกภาพสอดคล้องกันทั้งองค์กร เช่น การใช้ระบบป้องกันและควบคุมที่เหมาะสมกับระบบ อุปกรณ์เครือข่าย ระบบฐานข้อมูล หรือแม้แต่โปรแกรมต่างๆ การแบ่งหน้าที่ให้กับแต่ละบุคคลที่เกี่ยวข้องกับการดำเนินการ การดูแลทรัพยากรที่จำเป็นไม่ว่าจะเป็นฮาร์ดแวร์ หรือซอฟต์แวร์ให้อยู่ในสภาพที่ใช้งานได้ การเตรียมคอนแทกต์ลิสต์สำหรับติดต่อบุคคลที่เกี่ยวข้อง การเก็บหลักฐาน และการศึกษาหรือเตรียมการด้านกฎหมาย เป็นต้น

นอกจากนี้ส่วนที่สำคัญของการเตรียมการบางอย่างอาจเป็นหน้าที่ของผู้ดูแลระบบเองที่จะต้องจัดการดูแลอย่างมีประสิทธิภาพโดยอาจมีวิธีการดังต่อไปนี้

- ใช้นโยบายหรือกฎในการตั้งรหัสผ่านต่างๆ
- ลบบัญชีผู้ใช้ที่ไม่ได้ใช้งานทั้งหมดหรือระงับสิทธิ์การใช้งาน
- ติดตั้งเครื่องมือหรือโปรแกรมที่จำเป็นต้องใช้ เช่น เครื่องมือในการตรวจจับการบุกรุก เครื่องมือสำหรับการสืบหลักฐานหรือร่องรอยของการละเมิดความปลอดภัย
- เก็บรักษาล็อกไฟล์ของระบบ
- ลงส่วนเพิ่มเติมของโปรแกรม (patch) เพื่อลดจุดอ่อนหรือช่องโหว่ของโปรแกรมต่างๆ ในระบบ
- ตรวจสอบความถูกต้อง (integrity) ของระบบไฟล์
- สำรองข้อมูลของระบบเท่าที่จำเป็น
- สำรวจสิ่งที่น่าสงสัยที่เกิดขึ้นในระบบ ซึ่งโดยปกติแล้วจะถือเป็น เหตุการณ์ที่ไม่ปกติ

2.2.5 ขั้นตอนที่ 2 การตรวจสอบ (Detection)

การตรวจสอบคือการพยายามตรวจหาความผิดปกติหรือตรวจหาเหตุการณ์ที่อาจเป็นการละเมิดความปลอดภัยต่อระบบ โดยในการตรวจสอบนี้มักใช้เครื่องมือหรือโปรแกรมประเภทระบบตรวจจับการบุกรุก (Intrusion Detection System : IDS) เข้ามาช่วยในการตรวจสอบ โดยหลักๆ แล้วโปรแกรมเหล่านี้จะแบ่งเป็น Host-base IDS และ Network-base IDS ซึ่งมีคุณสมบัติในการทำงานต่างกัน

เหตุการณ์บางประเภทไม่จำเป็นต้องใช้โปรแกรมในการตรวจสอบ แต่อาจใช้วิธีการสังเกตจากการและข้อมูลที่อยู่ในระบบ เช่น ล็อกไฟล์ของระบบ ล็อกไฟล์ของไฟร์วอลล์ ตัวอย่างเหตุการณ์เช่น

- การพยายามทำการล็อกอินเข้าสู่ระบบและไม่สามารถเข้าสู่ระบบได้หลายๆ ครั้ง
- การล็อกอินเข้าสู่ระบบด้วยบัญชีผู้ใช้ (Account) ที่ถูกระงับสิทธิ์หรือบัญชีผู้ใช้ที่ระบบสร้างให้เป็นค่าเริ่มต้น ผู้ดูแลระบบสามารถตรวจสอบการล็อกอินเข้าสู่ระบบของผู้ใช้งานและควรจะสังเกตการใช้งานที่น่าสงสัยเช่น การล็อกอินเข้าสู่ระบบในช่วงเวลาที่ไม่ได้กำหนดการใช้งาน
- กิจกรรมบางอย่างที่เกิดขึ้นในช่วงเวลาที่ไม่มีการทำงาน ตัวอย่างเช่น การล็อกอินเข้าสู่ระบบในช่วงเวลาที่ไม่มีการทำงานหรือใช้ระบบแล้ว
- การเกิดบัญชีผู้ใช้ใหม่โดยที่ไม่ได้เป็นการสร้างจากผู้ดูแลระบบ
- การมีไฟล์หรือโปรแกรมที่แปลกปลอมในระบบ
- การเปลี่ยนแปลงสิทธิ์การใช้งานของไดเรกทอรีหรือไฟล์ต่างๆ
- การเปลี่ยนหน้าของเว็บเพจที่เก็บอยู่ในเครื่องให้บริการเว็บ
- การปรากฏรูปอนาจารในระบบ
- การใช้คำสั่งที่ไม่เกี่ยวข้องกับงานที่ทำของผู้ใช้นั้นๆ
- การเกิดช่องว่างในล็อกไฟล์เนื่องจากโดนลบข้อมูล
- การเปลี่ยนแปลงค่าการทำงานของระบบ DNS หรือการทำงานของเรเตอร์ หรือการเปลี่ยนกฎของไฟร์วอลล์
- ประสิทธิภาพการทำงานของระบบลดลงอย่างผิดปกติ
- ระบบไม่สามารถให้บริการได้ (system crash)

2.2.6 ขั้นตอนที่ 3 การยับยั้ง (Containment)

จุดมุ่งหมายของขั้นตอนนี้คือ การยับยั้งหรือหยุดการโจมตีและการทำความเข้าใจอันตราย ขั้นตอนนี้จะเริ่มขึ้นเมื่อมีการตรวจสอบพบเหตุการณ์ละเมิดความปลอดภัยแล้ว

หลังจากได้รับการยืนยันแล้วว่ามีการละเมิดความปลอดภัยเกิดขึ้นก็ควรจะมีการดำเนินการกับสิ่งที่เกิดขึ้นอย่างทันท่วงที การดำเนินการที่สามารถกระทำได้อย่างรวดเร็วและไม่ยุ่งยากคือ การยับยั้ง ตัวอย่างเช่น การระงับสิทธิ์การล็อกอินของบัญชีผู้ใช้ชั่วคราวหากตรวจสอบพบว่าการพยายามจะล็อกอินเข้าระบบด้วยรหัสผ่านที่ผิดหลายครั้งติดต่อกัน

สิ่งสำคัญสำหรับการยับยั้งคือ การทำให้การยับยั้งนั้นมีความเข้มแข็ง เพราะมีหลายเหตุการณ์ที่สามารถหลุดรอดออกไปได้อย่างรวดเร็ว ซึ่งอาจทำความเสียหายต่อระบบ เช่น การกระจายตัวของโค้ดหนอน ผู้ดูแลจะต้องจำกัดหรือยับยั้งการแพร่กระจายของโค้ดหนอนในเครือข่ายให้เร็วที่สุดเท่าที่จะเป็นไปได้

ก่อนที่จะมีการกระทำหรือดำเนินการใดๆ ในขั้นตอนนี้จะต้องมีการตัดสินใจก่อนว่าจะเลือกใช้วิธีการใดระหว่างการยับยั้งเหตุการณ์ในทันที หรือปล่อยให้ผู้ละเมิดความปลอดภัยดำเนินการต่อไปเพื่อที่ผู้ดูแลระบบสามารถทำการเก็บรวบรวมข้อมูลหรือหลักฐานต่างๆ ซึ่งอาจสามารถนำไปใช้ในการดำเนินการทางกฎหมายได้ แต่ทั้งนี้การที่จะตัดสินใจเลือกวิธีการใดจะต้องพิจารณาถึงความเสี่ยงที่ได้รับ ซึ่งแต่ละองค์กรมีระดับความเสี่ยงที่ยอมรับได้ต่างกัน หรือระดับความสำคัญหรือความลับของข้อมูลต่างกัน

สิ่งสำคัญพื้นฐานอีกประการของการยับยั้งคือ การตรวจสอบว่ามีการโจมตีใดบ้าง มีการติดตั้งโปรแกรมหรือโค้ดที่ไม่ประสงค์ดีอะไรบ้าง มีการติดตั้งโปรแกรมที่สร้างช่องทางสำหรับใช้ในการเข้าระบบอย่างไม่ถูกต้อง หลังจากตรวจสอบพบแล้วก็ต้องพิจารณาต่อไปว่าจะดำเนินการอย่างไรกับสิ่งที่ตรวจสอบพบเช่น ยังไม่ทำการลบหรือถอนออกจากระบบเนื่องจากต้องการเก็บไว้เป็นหลักฐานสำหรับดำเนินการทางด้านกฎหมายหรือ ทำการลบออกจากระบบทันทีและทำการเปลี่ยนรหัสผ่านของผู้ดูแลระบบเพื่อป้องกันมิให้ผู้โจมตีที่อาจรู้รหัสผ่านทำการเปลี่ยนรหัสผ่านนั้น

2.2.7 ขั้นตอนที่ 4 การกำจัด (Eradication)

จุดมุ่งหมายของขั้นตอนนี้คือ เพื่อทำการกำจัดสิ่งที่เป็นต้นเหตุของการละเมิดความปลอดภัย ในขั้นตอนนี้อาจใช้โปรแกรมเข้ามาช่วยได้เช่น การกำจัดไวรัสที่แพร่กระจายในระบบด้วยโปรแกรมจำพวก antivirus หากมีโปรแกรมจำพวกมัลแวร์ โทรจัน โปรแกรมหรือโค้ดที่สร้างช่องทางสำหรับการเข้าระบบซึ่งควรจะถูกกำจัดตั้งแต่ขั้นตอนการจำกัดขอบเขตหลงเหลืออยู่ในระบบ จะต้องทำการกำจัดในขั้นตอนนี้ ในบางกรณีหากไม่สามารถกำจัดโปรแกรมหรือโค้ดที่ไม่ประสงค์ดีเหล่านี้ได้อาจต้องทำการฟอร์แมต (Format) ฮาร์ดดิสก์ใหม่ซึ่งจะต้องทำการสำรองข้อมูลทั้งหมดไว้ก่อน สิ่งที่น่าสนใจคือ จะต้องแน่ใจว่าข้อมูลที่สำรองไว้นั้นปราศจากไวรัส หรือโปรแกรมที่ไม่ประสงค์ดีก่อนที่จะนำข้อมูลนั้นกลับมาใช้งาน

ตัวอย่างวิธีการในการกำจัดสิ่งที่ทำให้เกิดช่องโหว่ต่อระบบ หรือโปรแกรมที่ทำอันตรายต่อระบบปฏิบัติการยูนิกซ์ หรือลินุกซ์ มีดังนี้คือ

- 1) ตรวจสอบความผิดปกติในไฟล์ที่มีนามสกุลเป็น .forward
- 2) ใช้คำสั่ง ps เพื่อตรวจสอบรายชื่อโปรเซสที่กำลังทำงานและตรวจหาโปรเซสที่ผิดปกติหรือน่าสงสัย
- 3) ตรวจสอบการเปลี่ยนแปลงในไฟล์เหล่านี้คือ
 - /etc/dfs/dfstab (หรือ /etc/exports) - .cshc
 - .login - ทุกๆ ไฟล์ที่อยู่ในไดเรกทอรี /etc/rc
 - .logout - .rhosts
 - .profile - /etc/hosts.equiv
 - /etc/profile
- 4) ตรวจสอบการตั้งค่าการทำงานหรือการแก้ไขโปรแกรมให้ทำงานผิดปกติไปจากเดิมในโปรแกรมหรือไฟล์ดังต่อไปนี้
 - netstat - /etc/nsswitch.conf
 - ls - /etc/resolv.conf
 - sum - /var/spool/cron
 - find - /var/spool/cron/crontabs
 - diff - kerb.conf
- 5) ตรวจสอบวันเวลาของการแก้ไขไฟล์ด้วยคำสั่ง ls -lac
- 6) ตรวจสอบ suid ของโปรแกรมโดยใช้คำสั่ง
find / -type f -perm -4000 -ls หรือ
find / -type f -perm -4000 -print
- 7) ตรวจสอบการแก้ไขเปลี่ยนแปลงไฟล์ต่อไปนี้
 - /etc/passwd
 - shadow password file
 - /etc/group
 - yppasswd
- 8) ตรวจสอบการเพิ่มสิทธิ์ที่ไม่ได้รับการอนุญาตในไฟล์ .rhosts และไฟล์ /etc/hosts.equiv โดยใช้คำสั่งต่อไปนี้
find / -name .rhosts -ls -o -name .forward -ls
find / -name .rhosts -print -o -name .forward -print

9) ตรวจสอบการเปิดบริการ (service) ที่แปลกล้อมในไฟล์ต่อไปนี้ คือ

- /etc/inetd.conf
- /etc/inittab
- /etc/services
- /etc/hosts.allow
- /etc/hosts.deny

10) ค้นหาไฟล์ที่อาจถูกสร้างขึ้นในช่วงเวลาที่ระบบถูกโจมตีโดยใช้คำสั่งดังนี้

find / -ctime -1 -ls หรือ

find / -ctime -1 -print

หากตรวจสอบพบไฟล์ที่น่าสงสัยอาจทำการลบได้ตามความจำเป็น

11) ค้นหาไฟล์ที่อาจถูกเปลี่ยนแปลงในช่วงเวลาที่ระบบถูกโจมตีโดยใช้คำสั่งดังนี้

find / -mtime -1 -ls หรือ

find / -mtime -1 -print

หากตรวจสอบพบไฟล์ที่น่าสงสัยอาจดำเนินการใดๆได้ตามความจำเป็น

2.2.8 ขั้นตอนที่ 5 การกู้คืนระบบ (Recovery)

จุดมุ่งหมายของขั้นตอนนี้คือ เพื่อให้ระบบที่ถูกละเมิดความปลอดภัยกลับมาใช้งานได้
อย่างเป็นปกติ ความจำเป็นหรือระดับของการกู้คืนระบบนั้นแตกต่างกันตามแต่ละองค์กร
เนื่องจากแต่ละองค์กรอาจมีข้อมูลที่มีความสำคัญไม่เท่ากัน องค์กรใดที่ไม่จำเป็นต้องรักษาข้อมูล
หรือข้อมูลที่สูญเสียไปอาจไม่มีผลกระทบต่อองค์กรมากนักก็อาจจะใช้วิธีการฟื้นคืนระบบ
(restore) ใหม่ทั้งหมด ทั้งนี้วิธีการนี้จะต้องแน่ใจว่าข้อมูลที่สูญเสียไปนั้นจะไม่นำมาซึ่งความ
เสียหายต่อองค์กร นอกจากนี้อาจใช้วิธีการฟื้นคืนระบบกลับไปยังช่วงเวลาก่อนที่ระบบจะถูก
ละเมิดความปลอดภัยจนเกิดความเสียหายซึ่งวิธีนี้จะต้องอาศัยกลไกในการสำรองข้อมูลแบบ
อินครีเมนทอล (Incremental backup) ข้อดีของวิธีการนี้คือ ช่วยลดจำนวนข้อมูลที่สูญเสียไปและ
บรรเทาความเสียหายอันเนื่องมาจากการสูญเสียข้อมูลนั้น

สิ่งที่สำคัญที่อาจต้องนำมาพิจารณาคือ การฟื้นคืนระบบนั้นหากเป็นระบบที่มีความ
ซับซ้อนมากอาจต้องใช้เวลาในการฟื้นคืนระบบมาก ดังนั้นการที่จะเลือกใช้วิธีการกู้คืนระบบ
แบบใดควรจะต้องพิจารณาตามนโยบายขององค์กร

2.2.9 ขั้นตอนที่ 6 การติดตามผล (Follow – up)

ในขั้นตอนนี้ถือเป็นขั้นตอนสุดท้ายซึ่งมีจุดมุ่งหมายเพื่อรวบรวมข้อมูลที่เกี่ยวข้องกับ
เหตุการณ์ละเมิดความปลอดภัยที่เกิดขึ้น และแก้ไขระบบในส่วนที่เคยถูกละเมิดความปลอดภัย

ปรับปรุงให้มีความปลอดภัยมากขึ้นเพื่อป้องกันเหตุการณ์เดิมที่อาจเกิดขึ้นอีกครั้ง บางครั้งการติดตามผลอาจถูกมองข้ามไปทำให้การตอบสนองต่อการละเมิดความปลอดภัยนั้นไม่สมบูรณ์

ข้อมูลที่จะต้องทำการรวบรวมในขั้นตอนนี้ประกอบไปด้วยข้อมูลที่บ่งบอกถึง

- เกิดเหตุการณ์อะไรขึ้นกับระบบ
- ใครเป็นสาเหตุของเหตุการณ์นั้น
- เหตุการณ์นั้นทำให้ระบบเกิดการเปลี่ยนแปลงอย่างไร
- เหตุการณ์นั้นทำความเสียหายกับส่วนใดของระบบ

2.3 รูปแบบและพฤติกรรมของผู้บุกรุก

พฤติกรรมทั่วไปของผู้บุกรุก

อันดับแรกผู้บุกรุกพยายามหาข้อมูลของเครื่องเป้าหมายให้ได้มากที่สุดเท่าที่จะหาได้ ผู้บุกรุกอาจเข้าระบบโดยได้สิทธิ์ของผู้ใช้ปกติ แล้วเรียกใช้โปรแกรม เช่น whois (เป็นโปรแกรมที่ใช้หาข้อมูลว่ามีใครใช้งานอยู่ในระบบบ้าง) ดูโดเมนเนมของระบบ และค้นหาค่ากำหนดของเครื่องที่ทำงานอยู่ในเน็ตเวิร์ก เช่น ชื่อเครื่อง รุ่นของระบบปฏิบัติการ ชื่อผู้ใช้ทั้งหมดในระบบ

สำหรับภายในระบบ ผู้บุกรุกมักสแกนข้อมูลต่างๆ เพื่อหาช่องโหว่ เช่น เข้าไปตรวจสอบการใช้ CGI ในเว็บเพจ หรือใช้โปรแกรม ping หรือโปรแกรมที่ใช้พรโตคอลคล้ายกัน เช่น SNMP ในการค้นหาว่ามีเครื่องใดที่ยังเปิดให้บริการ หรือสแกนพอร์ตที่มีเซิร์ฟเวอร์ที่ใช้พรโตคอล TCP หรือ UDP เพื่อค้นหาว่ามีเซิร์ฟเวอร์อะไรที่เปิดให้บริการบ้าง ซึ่งข้อมูลเหล่านี้ใช้สำหรับการบุกรุกระบบ

หลังจากนั้น เมื่อผู้บุกรุกพยายามลัดเส้นเข้ามาในเครื่องเป้าหมาย โดยอาจใช้ช่องโหว่ในสคริปต์ซีจีไอ (CGI script) แล้วส่งคำสั่งหรือให้เรียกโปรแกรมใดๆ ส่งค่าไปเป็นอินพุตโดยผ่านทางคำสั่งเชลล์ หรือผู้บุกรุกพยายามหารหัสผ่านที่เดาได้ง่ายๆ หรือการเข้าใช้งานระบบโดยล็อกอินที่ไม่มีรหัสผ่าน เมื่อผู้บุกรุกสามารถเข้าไปเป็นผู้ใช้ทั่วไปแล้วก็สามารถหาช่องทางที่จะทำใหได้สิทธิ์ของผู้ดูแลระบบ

เมื่อผู้บุกรุกได้ข้อมูลที่ต้องการหรือได้ใช้ทรัพยากรใดๆ แล้ว สิ่งที่ทำต่อไปคือ การพยายามกลบเกลื่อนหลักฐานทั้งหมดในการบุกรุก หรือสร้างช่องทางให้สามารถกลับไปใช้ระบบนั้นๆ อีก โดยการสร้างประตูหลัง (Back door) หรือทำความเสียหายให้แก่ระบบนั้นโดยการวางโปรแกรมของข้อมูลในระบบ เพื่อตรวจสอบว่ามีการเปลี่ยนแปลงใดๆ ในไฟล์หรือองค์ประกอบอื่นในระบบหรือไม่ อีกพฤติกรรมหนึ่งของผู้บุกรุกคือ เมื่อบุกรุกระบบใดระบบหนึ่งได้ จะใช้เป็นช่องทางในการบุกรุกระบบอื่นๆ ต่อไป

ประเภทของการบุกรุก

การบุกรุกเข้าสู่ระบบแบ่งออกเป็นประเภทหลักๆ 3 ประเภทดังนี้

1. การบุกรุกทางกายภาพ (Physical Intrusion) ผู้บุกรุกพยายามบุกรุกที่เครื่องคอมพิวเตอร์โดยตรง โดยอาจมาใช้สิทธิ์พิเศษจากการทำงานที่คอนโซล หรือถอดย้ายอุปกรณ์ เช่น ฮาร์ดดิสก์ ซึ่งอาจนำไปเขียนหรืออ่านภายหลัง หรือบายพาสไบออสได้

2. การบุกรุกทางระบบ (System Intrusion) ผู้บุกรุกเข้ามาในระบบ โดยปกติมักเป็นผู้ใช้ที่มีสิทธิ์ต่ำ ถ้าระบบไม่ได้ทำการใส่แพตช์ (Patch) ที่สามารถแก้ไขข้อบกพร่องของโปรแกรมแล้ว จุดนี้ก็เป็นช่องโหว่ที่ทำให้ผู้ใช้นั้นสร้างสิทธิ์ของตัวเองให้มากขึ้น จนเทียบเท่าผู้ดูแลระบบได้ เนื่องจากโปรแกรมที่ใช้งานเกือบทุกโปรแกรมยังมีข้อบกพร่องอยู่ ถ้ายังไม่สามารถทำให้ข้อบกพร่องนั้นหมดไปหรือลดลงไปได้ จุดนี้ก็เป็นช่องทางสำหรับการบุกรุกระบบ

3. การบุกรุกระยะไกล (Remote Intrusion) ผู้บุกรุกติดต่อผ่านทางเน็ตเวิร์ก มีหลายเทคนิคในการบุกรุกระบบแบบนี้ ปัจจุบันมีโปรแกรมประเภทไฟร์วอลล์ (Firewall) ทำหน้าที่เป็นด่านแรกในการป้องกันการบุกรุกทางเน็ตเวิร์ก

ขั้นตอนหลักของการบุกรุกเข้าสู่ระบบ

ขั้นที่ 1 การตรวจสอบระบบจากภายนอก

ผู้บุกรุกจะพยายามปลอมแปลงตัวเองเพื่อไม่ให้รู้ว่าตัวเองคือใครและมีเจตนาอะไร โดยการปรากฏตัวเป็นผู้ใช้ทั่วไป ซึ่งในขั้นนี้เราไม่สามารถตรวจพบได้ ผู้บุกรุกอาจใช้คำสั่ง whois เพื่อค้นหาข้อมูลของเครือข่าย หลังจากนั้นผู้บุกรุกจะเข้าดูตาราง DNS ของเครือข่ายโดยใช้คำสั่ง nslookup หรือ dig เพื่อหาชื่อของคอมพิวเตอร์ในเครือข่าย

ขั้นที่ 2 การตรวจสอบระบบจากภายใน

ผู้บุกรุกใช้วิธีการบุกรุกต่างๆ เพื่อจะค้นหาข้อมูลของเครือข่าย โดยอาจเข้าเว็บเพจของระบบและค้นหา สคริปต์ซีจีไอ (CGI scripts) หรืออาจใช้วิธีการ ping กวาดไปทั่วระบบเพื่อดูว่ามีเครื่องไหนที่ทำงานอยู่ หรืออาจจะทำการใช้การสแกน ทีซีพี/ยูดีพี (TCP/UDP scan) ไปยังเครื่องเป้าหมายเพื่อดูว่ามีบริการอะไรที่เปิดรับอยู่ ณ จุดนี้สิ่งที่ผู้บุกรุกทำดูเหมือนจะเป็นพฤติกรรมที่ปกติที่เกิดขึ้นบนเครือข่ายและยังไม่มีสิ่งใดที่จะระบุได้ว่าเป็นการบุกรุก แต่ว่าระบบตรวจสอบผู้บุกรุกทางเครือข่ายจะสามารถบอกได้ว่า มีบางคนกำลังตรวจสอบระบบของเราอยู่ แต่ยังไม่สามารถทำอะไร

ขั้นที่ 3 การเจาะระบบ

ผู้บุกรุกจะเริ่มเจาะระบบผ่านทางช่องโหว่ของระบบ โดยผู้บุกรุกอาจจะพยายามส่ง สคริปต์ซีจีไอที่มีคำสั่งเชลล์ (shell) ในฟิลด์อินพุต (input fields) หรืออาจพยายามส่งข้อมูลจำนวนมากเพื่อทำให้เกิดบัฟเฟอร์โอเวอร์รัน (buffer-overflow) หรืออาจจะทำการหาข้อบกพร่องที่ง่ายต่อการ

คาดเดาพาสเวิร์ด เมื่อได้แอคเคาน์แล้วก็พยายามที่จะได้สิทธิ์เป็น root/admin หรือหาทางเข้ามาจากช่องโหว่ของโปรแกรมต่างๆ ที่ให้บริการอยู่บนเครื่องเป้าหมาย

ขั้นที่ 4 สร้างช่องทางลับและลบหลักฐาน

ณ จุดนี้ผู้บุกรุกจะสร้างช่องทางลับในระบบ โดยเจาะเข้าเครื่องคอมพิวเตอร์ในระบบนั้น เป้าหมายหลักเพื่อลบหลักฐานของการบุกรุกและทำให้แน่ใจว่าสามารถที่จะกลับเข้ามาอีกได้ โดยผู้บุกรุกจะติดตั้ง toolkit เพื่อให้สามารถเข้าระบบได้ หรือส่งม้าโทรจันไปฝังตัวไว้เพื่อสร้างพาสเวิร์ดแบ็กดอร์ (backdoor password) หรือสร้างแอคเคาน์ขึ้นใหม่เลย ทำให้สามารถเข้ามาอีกเมื่อไหร่ก็ได้

ขั้นที่ 5 แสวงหาผลประโยชน์

ผู้บุกรุกจะแสวงหาผลประโยชน์จากสิทธิ์ที่ตนได้รับโดยอาจขโมยข้อมูลลับ เช่น รหัสบัตรเครดิต หรือทำให้ระบบทำงานผิดพลาด หรืออาจใช้ระบบนี้เพื่อเป็นทางผ่านไปยังระบบอื่นหรือโจมตีระบบอื่นเพื่อไม่ให้รู้ตัวคนที่แท้จริงของผู้บุกรุก

2.4 ระบบตรวจจับผู้บุกรุก

ความหมายของระบบตรวจจับผู้บุกรุกระบบคอมพิวเตอร์

ระบบตรวจจับผู้บุกรุกระบบคอมพิวเตอร์ (Intrusion Detection System: IDS) เป็นส่วนให้ความช่วยเหลือระบบคอมพิวเตอร์ ในการเตรียมการรับมือกับการบุกรุก ระบบตรวจจับผู้บุกรุกระบบคอมพิวเตอร์รวบรวมข้อมูลจากแหล่งข้อมูลหลายๆ แหล่งทั้งจากภายในระบบและจากเครือข่ายคอมพิวเตอร์ แล้วทำการวิเคราะห์ข้อมูลเหล่านั้นเพื่อหาลักษณะการที่บ่งบอกว่ามีการบุกรุกระบบเกิดขึ้น ในบางกรณีระบบตรวจจับผู้บุกรุกระบบคอมพิวเตอร์อาจอนุญาตให้ผู้ใช้กำหนดวิธีการตอบสนองต่อการบุกรุกเองได้

กล่าวโดยสรุปแล้วระบบตรวจจับผู้บุกรุกระบบคอมพิวเตอร์ คือ ระบบที่ทำหน้าที่ติดตามการทำงานของระบบคอมพิวเตอร์ เพื่อค้นหาร่องรอยที่บ่งบอกว่ามีผู้กำลังพยายามบุกรุกระบบคอมพิวเตอร์ หรือค้นหาการกระทำที่เกินขอบเขตสิทธิ์ของผู้ใช้ระบบ

ผู้บุกรุกระบบคอมพิวเตอร์หรือ Intruder หมายถึง บุคคลที่พยายามบุกรุกหรือได้บุกรุกเข้ามาในระบบโดยที่ไม่ได้รับอนุญาต หมายความว่าบุคคลที่เรียกว่า แฮ็กเกอร์ (Hacker) คือผู้ที่ชอบเข้าไปศึกษาบางสิ่งบางอย่างในระบบ เช่น เข้าไปศึกษาหลักการทำงานของระบบและโปรแกรม

ความจำเป็นของระบบตรวจจับผู้บุกรุกระบบคอมพิวเตอร์

ผู้ดูแลระบบอาจคิดว่าในระบบที่ตนดูแลอยู่ไม่มีข้อมูลสำคัญ ถึงแม้ผู้บุกรุกเข้ามาก็ไม่เป็นไร แต่ความเป็นจริงแล้วสามารถเกิดกรณีที่มีผู้บุกรุกเข้ามายังระบบ แล้วใช้เป็นทางผ่านในการเจาะระบบของธนาคาร หรือหน่วยงานที่มีข้อมูลสำคัญ และเข้าไปทำความเสียหายให้กับระบบ

นั้นๆ ถ้ามีการตรวจสอบกลับมา เจ้าของระบบต้องเป็นผู้รับผิดชอบกับเหตุการณ์ที่เกิดขึ้น ดังนั้น การรักษาความปลอดภัยของระบบจึงเป็นเรื่องจำเป็นที่ละเลยไม่ได้

การบุกรุกถ้าแบ่งจากสถานที่ที่ติดต่อเข้ามาของผู้บุกรุก สามารถแบ่งได้เป็น 2 ประเภทคือ การบุกรุกจากภายในเครือข่ายเอง และบุกรุกจากภายนอกเครือข่าย

การบุกรุกจากภายนอกเป็นการบุกรุกที่มาจากภายนอกเครือข่ายของระบบ และเข้ามาทำความเสียหายให้แก่ระบบ เช่น เข้ามาเปลี่ยนข้อมูลในโฮมเพจ หรือส่งสแปมเมลล์ไปให้ผู้อื่น โดยผ่านระบบของหรือพยายามบุกรุกผ่านไฟร์วอลล์เข้ามาทำความเสียหายให้กับเครื่องที่อยู่ภายในเน็ตเวิร์ก ผู้บุกรุกจากภายนอกสามารถเข้ามาโดยผ่านบริการ (Service) ของระบบ หรือติดต่อผ่านโมเด็มเข้ามา

การบุกรุกจากภายในเป็นการบุกรุกโดยผู้ที่มีสิทธิ์อันชอบธรรมที่เข้ามาใช้ทรัพยากรในระบบ แต่ใช้งานทรัพยากรอย่างไม่ถูกต้อง หรือพยายามแอบอ้างไปใช้สิทธิ์ของผู้อื่นที่มีสิทธิ์ในการใช้งานเหนือกว่า

ชนิดของระบบตรวจจับผู้บุกรุกระบบคอมพิวเตอร์

ระบบตรวจจับผู้บุกรุกระบบคอมพิวเตอร์สามารถแบ่งได้เป็น 2 ชนิด คือ

1. ระบบตรวจจับผู้บุกรุกในโฮสต์ (Host-based Intrusion Detection System)
2. ระบบตรวจจับผู้บุกรุกเครือข่าย (Network Intrusion Detection System)

2.4.1 Host based IDS

เป็นโปรแกรมที่จะตรวจสอบข้อมูลจากเครื่องหรือจากระบบ โดยมีข้อดีกว่า network-base คือเราสามารถรู้ได้ว่าการเปลี่ยนแปลงอะไรบ้างที่เครื่องเรา

โดยส่วนมากโปรแกรมประเภท host-base IDS จะตรวจสอบค่าหรือข้อมูลที่เก็บอยู่ใน log file และตรวจสอบค่า integrity checksum โดยจะตรวจสอบหาการกระทำที่ผิดปกติอย่างเช่น มีการปรับเปลี่ยนข้อมูล มีการลบข้อมูล มีการเข้าถึงข้อมูล มีการเปลี่ยนแปลงระบบ มีการลงโปรแกรม มีการหลีกเลี่ยงการตรวจจับหรือการตรวจสอบ เป็นต้น

การใช้ค่า logs ในการตรวจสอบนั้นโดยส่วนมากจะไม่ใช้เพียงไฟล์ใดไฟล์เดียวแต่จะเป็นการเอาค่า logs ต่างๆมาทำการ cross-check เพื่อตรวจสอบ โดย host-base IDS ที่ดีนั้นจะทำการ cross-check ค่า logs และ system activity

ในการเก็บล็อกจะต้องพิจารณาถึง ลักษณะการเก็บ ปริมาณจะเก็บ พื้นที่ที่ต้องใช้ในการเก็บล็อก รวมไปถึงเวลาที่ต้องเสียไปในการตรวจสอบ

2.4.1.1 Unix logs (syslogd)

โปรแกรม syslogd เป็นกลไกที่ใช้ในการเก็บข้อมูลต่างๆ ของ kernel และ application บนระบบยูนิกซ์และลินุกซ์ลงล็อกไฟล์ โดยโปรแกรม syslogd นี้จะเป็น daemon ที่ถูกติดตั้งมาให้พร้อมกับระบบปฏิบัติการในเกือบทุกระบบ โดยผู้ดูแลระบบสามารถปรับแต่งไฟล์ configuration เพื่อปรับแต่งลักษณะการทำงานของ syslogd ได้ เช่น ให้ syslogd เก็บข้อมูลไปไว้ที่ไฟล์ใด หรือให้ส่งข้อมูลล็อกนี้ไปเก็บไว้ยังเครื่องอื่นในเครือข่าย

ข้อมูลล็อกที่ควบคุมโดย syslogd นั้น จะถูกกำหนดให้มีค่า facility และ priority โดยส่วนของ facility นั้น เป็นข้อมูลที่อธิบายถึงแหล่งกำเนิดของข้อมูลล็อกนั้นๆ เช่น ข้อมูลล็อกที่ส่งมาจากระบบเมลก็จะมี facility เป็น mail ส่วน priority นั้น จะแสดงถึงระดับความสำคัญของเหตุการณ์ที่เกิดขึ้นสำหรับแต่ละ facility ทั้งนี้ข้อมูลล็อกทุกอันจำเป็นต้องมี facility และ priority เสมอ

ตารางที่ 2.1 แสดงค่า facility และความหมาย

Facility	คำอธิบาย
auth	เกี่ยวข้องกับการทำ authentication
authpriv	การทำ private authentication เท่านั้น
cron	cron daemon
daemon	system daemons
kern	ส่วนของ kernel
lpr	line printer spooling system
mail	sendmail และซอฟต์แวร์อื่นที่เกี่ยวข้องกับเมล
mark	ให้บันทึกเวลาขณะเกิดเหตุการณ์ด้วย
news	usenet news system
security	เหมือนกับ auth
syslog	ข้อมูลล็อกภายในของ syslogd
user	ส่วนของโปรเซสของ user
uucp	สำรองไว้สำหรับ UUCP
local0 - local7	local messages

ตารางที่ 2.2 แสดงค่า priority และความหมาย

Priority	คำอธิบาย
emerg	ภาวะฉุกเฉิน
alert	แจ้งเตือนเร่งด่วน
crit	ล่อแหลม
err	มีข้อผิดพลาด
warning	คำเตือน
notice	ข้อสังเกต
info	ข้อมูลทั่วไป
debug	สำหรับใช้ดีบั๊กเท่านั้น

การทำงานของ syslogd นั้น จะขึ้นอยู่กับไฟล์ /etc/syslog.conf เป็นหลัก การแก้ไขใดๆ ที่เกิดขึ้นกับไฟล์นี้ จะยังไม่มีผลต่อการทำงานของ syslogd ในทันที จะต้องทำการ restart syslogd service ใหม่เสียก่อน รูปแบบคำสั่งในไฟล์ /etc/syslog.conf นั้นมีรูปแบบดังนี้

facility.level	action
facility1, facility2.level	action
facility1.level1; facility2.level2	action
*.level	action
*.level;badfacility.none	action

หมายความว่า เมื่อมีข้อมูลล็อกที่มี facility และ level ที่ตรงหรือมากกว่ากับที่ตั้งไว้ ก็จะกระทำ action ตามที่กำหนดไว้ ทั้งนี้เพราะ level ที่ตั้งไว้นั้น เป็นค่า minimum ซึ่งหมายความว่าถ้าเราตั้ง level เป็น debug ก็จะครอบคลุมทุก level ของ facility นั้นๆ เลย ทั้งนี้เราสามารถใส่เครื่องหมาย * แทนทุกๆ ค่าใน facility หรือ priority level นั้นๆ ได้ เช่น mail.* /var/log/mail หมายความว่าให้ syslogd เก็บข้อมูลล็อกของ mail ทุก level ไปไว้ยังไฟล์ /var/log/mail

ในขณะที่ level ที่เป็น none นั้น หมายความว่าไม่ให้สนใจ facility ที่ประกาศค่า level เป็น none เช่น *.emerg;mail.none /var/log/emerg.log คือให้เก็บข้อมูลล็อกที่มี level เป็น emerg สำหรับทุก facility ยกเว้น mail facility

สำหรับ action นั้นสามารถเลือกได้ดังนี้คือ

- filename : เก็บข้อมูลล็อกนั้นลงในไฟล์ที่กำหนด
 - @hostname : ส่งต่อข้อมูลล็อกไปยัง syslogd บน host ที่กำหนด
 - @ipaddress : ส่งต่อข้อมูลล็อกไปยัง host ที่มี ip address ตามที่กำหนด
 - user1, user2 : ส่งข้อมูลล็อกไปยังหน้าจอของ user ที่กำหนด ถ้า user เหล่านั้นยังล็อกอินอยู่ในระบบ
 - * : ส่งข้อมูลล็อกไปยังทุกๆ user ที่ยังล็อกอินอยู่ในระบบ
 - /dev/console เพื่อส่งข้อมูลล็อกไปยัง console device หรือ device อื่นๆ ตามที่ต้องการ
- สำหรับ Red Hat นั้นได้ขยายความสามารถของ syslogd เพิ่มเติม โดยอนุญาตให้ข้อมูลล็อกสามารถถูกส่งแบบ pipe ไปยังไฟล์ได้ โดยแก้ไขใน syslog.conf และยังสามารถใช้เครื่องหมาย = และ ! ใน syslog.conf ได้โดย
- เครื่องหมาย = หมายถึง priority ที่กำหนดเท่านั้น
 - เครื่องหมาย ! หมายถึง priority อื่นที่ไม่ใช่ priority นี้และสูงกว่า

ตัวอย่าง เช่น

- mail.info ความหมายคือ ข้อมูลล็อกที่เกี่ยวข้องกับเมลล์และมี priority เป็น info และสูงกว่า
- mail.=info ความหมายคือ ข้อมูลล็อกที่เกี่ยวข้องกับเมลล์และมี priority เป็น info เท่านั้น
- mail.info;mail.!err ความหมายคือ ข้อมูลล็อกที่เกี่ยวข้องกับเมลล์และมี priority เป็น info , notice และ warning
- mail.debug;mail.!=warning ความหมายคือ ข้อมูลล็อกที่เกี่ยวข้องกับเมลล์และมี priority ทุกระดับที่ไม่ใช่ warning

โดยปกติ Red Hat จะเก็บข้อมูลล็อกไว้ในไฟล์ซึ่ง อยู่ภายใต้โฟลเดอร์ /var/log และถูกติดตั้งมาพร้อมกับ logrotate ซึ่งเป็นเครื่องมือที่ช่วยจัดการล็อกไฟล์ได้อย่างมีประสิทธิภาพ ปกติแล้วจะ rotate ล็อกไฟล์อาทิตย์ละครั้ง และจะเก็บล็อกไว้ 4 รอบ หรือ 1 เดือน ผู้ดูแลระบบสามารถปรับเปลี่ยนค่าเหล่านี้ได้ที่ /etc/logrotate.conf

ตัวอย่างของไฟล์ configuration สำหรับ stand-alone machine

- *.emerg *
ความหมาย ในกรณีฉุกเฉินให้แจ้งเตือน user ทุกคนที่ล็อกอินอยู่
- *.warning;daemon,auth.info,user.none /var/log/messages
ความหมาย เก็บข้อมูลล็อกที่สำคัญไว้ในไฟล์
- lpr.debug /var/log/lpd-errs
ความหมาย printer errors

ตัวอย่างของไฟล์ *configuration* สำหรับ *network client*

- *.emerg;user.none*
ความหมาย ในกรณีฉุกเฉินให้แจ้งเตือน user ทุกคนที่ล็อกอินอยู่
- *.warning;lpr,local1.none @netloghost
daemon,auth.info @netloghost
ความหมาย ส่งข้อมูลล็อกที่สำคัญไปยังเครื่องที่ทำหน้าที่เก็บล็อก
- local2.info;local0,local7.debug @netloghost
ความหมาย ส่งข้อมูลล็อกของ local ไปยังเครื่องที่ทำหน้าที่เก็บล็อก
- lpr.debug /var/log/lpd-errs
ความหมาย printer errors
- local2.info /var/log/sudo-logs
ความหมาย ข้อมูลของ sudo ที่ local2 ให้เก็บไว้ในไฟล์
- kern.info /var/log/kern.log
ความหมาย ข้อมูลของ kernel ให้เก็บไว้ในไฟล์

ในกรณีนี้ข้อมูลส่วนใหญ่จะถูกส่งไปยังเครื่องที่ทำหน้าที่เก็บล็อก ซึ่งหมายความว่าถ้าเครื่องนั้นไม่สามารถให้บริการได้ข้อมูลล็อกก็จะสูญไป ดังนั้นจึงควรเก็บข้อมูลล็อกบางส่วนไว้ที่เครื่องของตัวเองด้วย

ตัวอย่างของไฟล์ *configuration* สำหรับ *central logging host*

- *.emerg /dev/console
*.err;kern,mark.debug;auth.notice /dev/console
*.err;kern,mark.debug;user.none /var/log/console.log
auth.notice /var/log/console.log
ความหมาย ในกรณีฉุกเฉินให้ส่งข้อมูลไปยัง console และล็อกไฟล์โดยมีเวลากำหนดด้วย
- *.err;user.none;kern.debug /var/log/messages
daemon,auth.notice;mail.crit /var/log/messages
lpr.debug /var/log/lpd-errs
mail.debug /var/log/mail.log
ความหมาย ส่งข้อมูลล็อกที่ไม่ใช่ข้อมูลฉุกเฉินไปยังไฟล์ธรรมดา

- local2.debug /var/log/sudo.log
 local2.alert /var/log/sudo-errs.log
 auth.info /var/log/auth.log
 ความหมาย เก็บข้อมูลที่เกี่ยวข้องกับการทำ authorization เช่น sudo
- local7.debug /var/log/tcp.log
 ความหมาย และข้อมูลอื่นๆ
- user.info /var/log/user.log
 ความหมาย ข้อมูลของ user

ข้อควรระวังคือ ในกรณีที่เวลาของแต่ละเครื่องไม่ตรงกันนั้นอาจจะก่อให้เกิดความยุ่งยากมากทีเดียว เพราะเวลาที่เขียนลงในล็อกไฟล์นั้นเป็นเวลาของเครื่องที่ทำหน้าที่บันทึกข้อมูลล็อก ไม่ได้ดึงมาจาก เครื่องที่ส่งข้อมูลล็อกมาให้แต่อย่างใด ดังนั้นจึงควรทำ clock synchronize ในทุกๆ เครื่องเพื่อให้เวลาที่บันทึกข้อมูลลงล็อกไฟล์นั้นตรงกัน

ตารางที่ 2.3 แสดงรายชื่อซอฟต์แวร์ที่ใช้ syslog

Program	Facility	Levels	Description
amd	daemon	err-info	NFS automounter
date	auth	notice	Set the time and date
ftpd	daemon	err-debug	FTP daemon
gated	daemon	alert-info	Routing daemon
halt/reboot	auth	crit	Shutdown programs
inetd	daemon	err, warning	Internet super-daemon
login/rlogind	auth	crit-info	Login programs
lpd	lpr	er-info	BSD line printer daemon
named	daemon	err-info	Name server (DNS)
nnrpd	news	crit-notice	INN news reader
ntpd	daemon, user	crit-info	Network time daemon

Program	Facility	Levels	Description
passwd	auth	err	Password-setting program
popper	local0	notice, debug	Mac/PC mail system
sendmail	mail	alert-debug	Mail transport system
su	auth	crit, notice	Switches UIDs
sudo	local2	alert, notice	Limited su program
syslogd	syslog, mark	err-info	Internal errors, timestamps
tcpd	local7	err-debug	TCP wrapper for inetd
cron	cron, daemon	info	System task-scheduling daemon
vmunix	kern	<i>varies</i>	The kernel

สำหรับการดีบั๊กหรือทดสอบการทำงานของ syslog ว่าทำงานหรือไม่นั้น สามารถทำได้ โดยไม่ยากนัก เช่นเพิ่มบรรทัดด้านล่างนี้ใน syslog.conf

local5.warning /var/log/test.log

จากนั้นให้ restart syslog ใหม่ แล้วจึงรันคำสั่ง `#logger -p local5.warning "test"` ซึ่งถ้าเป็นไปตามปกติแล้ว ในไฟล์ `/var/log/test.log` ก็จะมีคำว่า test ปรากฏอยู่ด้วย

สำหรับ Red Hat ที่ต้องการทำหน้าที่เป็นเครื่องที่ทำหน้าที่เก็บข้อมูลล็อกสำหรับเครื่องอื่นๆ ภายในเครือข่าย สามารถแก้ไขได้โดยเพิ่ม `-r` ใน startup options ของ syslog daemon โดยแก้ไขได้ที่ `/etc/sysconfig/syslog` หรือที่ `/etc/rc.d/init.d/syslog`

ข้อสังเกต

syslog นั้นเป็นมาตรฐานสำหรับการทำ logging ของยูนิกซ์และลินุกซ์ แต่ syslog กำลังจะถูกแทนที่โดย syslog-ng (syslog new generation) ซึ่งมีความยืดหยุ่นมากกว่า standard syslog และสามารถเก็บข้อมูลล็อกบนพื้นฐานของ regular expression ได้

สำหรับการตรวจสอบล็อกไฟล์นั้น โดยปกติควรจะตรวจสอบอย่างน้อยวันละหนึ่งครั้ง แต่เนื่องจาก ล็อกไฟล์โดยส่วนใหญ่มักจะมีขนาดใหญ่ บางครั้งผู้ดูแลระบบเองอาจจะเผลอเรอ หรือมองข้าม ในบางจุดไป ซึ่งอาจจะก่อให้เกิดความเสียหาย ต่อระบบได้ การนำ Swatch และ Logwatch มาใช้งาน จะช่วยลดปัญหาเรื่องการสูญเสียเวลาได้ สำหรับ Swatch นั้น เป็น daemon ที่ทำหน้าที่ตรวจสอบรูปแบบ (pattern matching) ของล็อกไฟล์ เมื่อเจอข้อมูลที่ต้องการก็สามารถ

รัน script หรือ โปรแกรมอื่นได้ เช่นอาจจะสั่งให้ส่งอีเมลล์ ส่งเสียงบีบ ส่วน Logwatch นั้นทำงานบน cron job มีหน้าที่ในการตัดข้อมูลล็อก แล้วส่งผ่านอีเมลล์ไปยังผู้ดูแลระบบ เนื่องจากการส่งข้อมูล ล็อกไปยังเครื่องที่ทำหน้าที่เก็บข้อมูลล็อกอื่นนั้น ไม่มีกระบวนการของการตรวจสอบและยืนยันตัวตน และทำงานโดยใช้ UDP port 514 (user datagram protocol) ซึ่งเป็นโปรโตคอลที่ไม่มีการรับประกันการส่งข้อมูล และยังสามารถปลอมแปลง header ได้โดยง่าย ดังนั้นผู้ดูแลระบบควรติดตั้งไฟร์วอลล์เพื่อป้องกันไม่ให้เครื่องจากภายนอกส่งข้อมูลล็อกมายังเครื่องที่ทำหน้าที่เก็บข้อมูลล็อกดังกล่าว

ข้อเสียของ syslogd

- 1) เนื่องจาก syslog เป็นการส่งข้อมูลแบบ udp ทำให้ผู้ส่งไม่ได้รับความมั่นใจว่าข้อมูลที่ส่งไปให้เครื่อง server นั้น จะไปถึงหรือไม่
- 2) การที่ไม่มีการทำ authentication ก่อนว่าใครคือคนส่ง ก็อาจจะนำไปสู่การส่งข้อมูลปลอมปลอมปนเข้าไปยังเครื่อง log server เพื่อไปชักนำให้การตามรอยผู้บุกรุก เกิดหักเหไปสู่ทิศทางที่ไม่ถูกต้อง และยังสามารถทำให้เกิด DoS ได้
- 3) การส่งข้อมูล plaintext โดยไม่มีการเข้ารหัสก่อนที่จะส่ง อาจจะทำให้ผู้ไม่หวังดีสามารถดักจับข้อมูลไปดู และอาจจะทำให้รู้ได้ว่าระบบเราลงโปรแกรมอะไรบ้าง มีช่องโหว่หรือจุดอ่อน อะไรซึ่งอาจจะนำไปสู่การโจมตีหรือละเมิดความปลอดภัยได้

2.4.1.2 syslog-ng

เป็นโปรแกรมที่ปรับปรุงมาจาก syslogd โดยมีความสามารถที่เพิ่มเติมเข้ามาคือ

- สามารถทำการรับส่งข้อมูลผ่าน protocol TCP ซึ่งมีการรับประกันความถูกต้องของข้อมูล ทำให้น่าเชื่อถือ แทนที่จะเป็นการส่งโดยผ่าน protocol UDP ซึ่งไม่มีการรับประกันความถูกต้องของข้อมูล ทำให้การส่งข้อมูลนั้นไม่น่าเชื่อถือและไม่ปลอดภัย การที่ใช้การเชื่อมต่อแบบ TCP ทำให้สามารถที่จะทำการเข้ารหัสและตรวจสอบ cert เพิ่มขึ้นมาได้ ซึ่งจะมีประโยชน์ในการตรวจสอบฝั่งที่ส่งและฝั่งที่รับได้
- สามารถที่จะใช้ตัวกรองเพื่อกรองข้อมูลได้ โดยสามารถกรองจาก regular expression
- สามารถปรับแต่งการทำงานได้ยืดหยุ่นมากกว่า ซึ่งเป็นประโยชน์ต่อการนำไปใช้
- สามารถกำหนดให้มีการไว้วางใจในชื่อ hostname ที่ส่งมาได้ ซึ่งโดยปกติค่าเริ่มต้นจะตั้งค่าไว้ว่าไม่ให้ไว้วางใจ โดยจะไปทำการ resolve จาก source IP ของแพ็คเกจที่เข้ามาแทนเพื่อป้องกันการปลอม hostname ซึ่งใน syslogd จะเชื่อค่า hostname ที่ส่งเข้ามา
- สามารถกำหนด queue ที่จะให้รับข้อมูลได้ว่าจะให้มากขนาดไหน
- สามารถกำหนด จำนวน connection ต่อ port ที่ให้รับนั้นได้ เพื่อป้องกันการคับคั่งของข้อมูล

ปัญหาของ syslog-ng คือ

- 1) ไม่มีการเข้ารหัสในการรับส่งข้อมูล
- 2) ไม่มีการทำ authentication ในระหว่างการรับส่งข้อมูล

2.4.1.3 Tripwire

เป็นโปรแกรมในยุคเริ่มต้นของโปรแกรมประเภท host-based IDS ซึ่งภายหลังตัวโปรแกรม tripwire นี้ก็ถูกนำมาพัฒนาต่อกลายเป็นโปรแกรม host-based IDS ตัวอื่นๆ

การทำงาน

การทำงานของตัวโปรแกรม tripwire เริ่มจากการคำนวณค่า message digest ของแต่ละไฟล์ เก็บไว้ใน database เป็นค่าเริ่มต้น โดยค่าที่เก็บครั้งแรกนั้นเป็นค่าที่เก็บเมื่อระบบยังไม่ถูกละเมิดสิทธิ์ เป็นค่าที่ระบบยังปกติอยู่ ในการตรวจสอบระบบแต่ละครั้ง ตัวโปรแกรมก็จะทำการคำนวณค่า message digest ออกมาใหม่เพื่อเอาไปเปรียบเทียบกับค่าที่เก็บไว้ในตอนแรก ถ้าค่า message digest แตกต่างจากค่าที่เก็บไว้เมื่อตอนเริ่มต้นก็แสดงว่า มีการเปลี่ยนแปลงเกิดขึ้นกับไฟล์นั้น

Message digest คือไฟล์ชนิดพิเศษที่ผ่านกระบวนการเข้ารหัส โดยค่าที่ได้ขึ้นอยู่กับข้อมูลภายในไฟล์นั้นๆ message digest ถูกออกแบบมาให้ยากมากที่จะคำนวณค่าออกมาเหมือนเดิมหรือที่จะคำนวณข้อมูล 2 ชุดได้ค่า message digest เหมือนกัน และยังมีคุณสมบัติในการป้องกันไม่ให้พิจารณาไปถึงค่าเริ่มต้นของข้อมูลได้ (ไม่สามารถถอดรหัส message digest ได้)

โดยปกติสำหรับ unix,linux จะใช้ md5sum ในการคำนวณค่า message digest ออกมา ซึ่งสามารถทดสอบได้โดยการใช้คำสั่ง md5sum ตามด้วยชื่อไฟล์ การเปลี่ยนค่าเพียงแค่ 1 บิตก็จะทำให้ค่า message digest มีค่าที่ไม่เหมือนเดิม ซึ่งมันเป็นไปได้ที่มีคนเปลี่ยนค่าในไฟล์แล้วจะได้ค่า message digest เป็นค่าเดิม

จากคุณสมบัติดังกล่าวทำให้ โปรแกรม tripwire เหมาะสำหรับการตรวจสอบไฟล์ที่มีความเสี่ยง โดยเราสามารถเข้าไปกำหนดค่าว่าจะให้ทำการตรวจสอบไฟล์ใดบ้างได้ที่ tw.pol

ข้อแนะนำ ในการเก็บค่า message digest ในครั้งแรกควรเก็บเอาไว้ที่ floppy disk หรือควรเก็บเอาไว้ที่แผ่น CD-ROM โดยไปทำการแก้ค่าได้ในไฟล์ configure

```
phantomb@Isag27:~/tmp$ md5sum server.pem
914822e263459a98b3d3c9a39887d09e server.pem
phantomb@Isag27:~/tmp$ md5sum server.pem
914822e263459a98b3d3c9a39887d09e server.pem
phantomb@Isag27:~/tmp$ nano server.pem
phantomb@Isag27:~/tmp$ md5sum server.pem
022a86914feb6608858cfdb3276772a1 server.pem
```

รูปที่ 2.2 แสดงตัวอย่างการหา checksum

จากรูปตัวอย่าง ได้ทำการเอาไฟล์ server.pem มาเข้า checksum โดย ครั้งแรกได้ค่าเก็บไว้ แล้วลอง ทำอีกครั้งโดยไม่เปลี่ยนค่าใดๆในไฟล์ ส่วนครั้งสุดท้ายทำการลบตัวอักษรออก 1 ตัว ก็จะได้ค่าไม่เหมือนเดิม

2.4.1.4 Samhain

เป็นโปรแกรมตรวจสอบความถูกต้องของข้อมูล เช่นเดียวกับ tripwire แต่ว่าตัวโปรแกรม samhain เป็นโปรแกรมที่พัฒนาอย่างต่อเนื่อง และทันสมัยมากกว่า โปรแกรม tripwire ที่หยุดการพัฒนาไปตั้งแต่ปี 2001 ทำให้สามารถตรวจสอบได้มากกว่า ป้องกันการหลีกเลียงได้มากกว่า และ มีการเพิ่มเติมในส่วน interface มากขึ้นเพื่อให้สามารถใช้งานได้มากกว่า

คุณสมบัติหลักที่สำคัญของโปรแกรม samhain มีดังนี้คือ

- 1) สามารถตรวจสอบไฟล์ประเภท suid และ sgid ได้
- 2) โปรแกรมทำงานที่ระดับ kernel ทำให้สามารถตรวจสอบโปรแกรม ประเภท rootkit ที่อาจจะถูกติดตั้งที่ kernel ของระบบได้
- 3) สามารถซ่อน process ให้มองไม่เห็นได้
- 4) สามารถสั่งให้โปรแกรมทำงานแบบ background ได้ (daemon) เพื่อให้โปรแกรมคอยตรวจสอบความถูกต้องอยู่ตลอดเวลา
- 5) สามารถเก็บข้อมูลการตรวจสอบ และไฟล์ฐานข้อมูลสำหรับเปรียบเทียบไว้ที่เครื่องกลางได้
- 6) สามารถเก็บข้อมูลการตรวจสอบลงฐานข้อมูล ได้เพื่อให้ง่ายต่อการตรวจสอบ
- 7) มีการ sign ฐานข้อมูลเพื่อเป็นการยืนยันความถูกต้องของฐานข้อมูล
- 8) มีการ sign ข้อมูล output (ข้อมูลที่ตรวจสอบมา) และ มีการเข้ารหัสเมื่อส่งเข้าไปที่เครื่องกลาง

- 9) สามารถตรวจสอบการ mount file system ได้
- 10) สามารถเลือกวิธีที่จะใช้ในการหาค่า checksum ได้ โดยมีวิธีการ 3 อย่างให้เลือกคือ tiger192, md5 และ sha-1
- 11) มีการฝัง password ตอน compile เพื่อเอาไปใช้ตอน connect กับ ตัว server
- 12) สามารถใช้ server ควบคุมและตรวจสอบการทำงานของ client ได้

2.4.2 Network based IDS and IPS

หลักการทำงานพื้นฐานของระบบตรวจจับผู้บุกรุกทางเครือข่ายก็คือ การดักจับแพ็กเก็ตที่ผ่านเข้ามายังเครือข่ายและนำข้อมูลจากแพ็กเก็ตนั้นมาวิเคราะห์ เพื่อตรวจสอบว่ามีลักษณะตรงกับรูปแบบการบุกรุกหรือไม่ เมื่อตรวจพบลักษณะที่ตรงกับการบุกรุกก็อาจจะทำการ แจ้งเตือนผู้ดูแลระบบ หรือทำการส่งข้อมูลไปเก็บลงระบบเก็บล็อกต่อไป แต่ถ้าเป็น IPS ก็สามารที่จะทำการ drop หรือ block แพ็กเก็ตนั้นทิ้งไปได้เลย โดยถ้าต้องการให้เครื่องของเรารับข้อมูลแพ็กเก็ตเข้ามาพิจารณา ก่อน โดยไม่สนว่าเป็นของใคร จะเรียกว่า โพรมิสคูอัสโหมด (promiscuous mode) เป็นโหมดที่อนุญาตให้ฮาร์ดแวร์รับข้อมูลดิบทั้งหมดบนเน็ตเวิร์กที่เข้ามาในเครื่องคอมพิวเตอร์ของตนเอง โดยที่ไม่สนใจว่าจะเป็นของใคร ส่งให้ใคร และเป็นการละเมิดข้อบังคับของโปรโตคอลหรือไม่

ลักษณะของซิกเนเจอร์ที่ใช้ในการตรวจสอบ

การวิเคราะห์แพ็กเก็ตนั้นจะสนใจแพ็กเก็ตที่มีลักษณะซิกเนเจอร์ตรงกับที่มีข้อมูลอยู่ ซิกเนเจอร์แบ่งออกได้เป็น 3 ประเภทดังนี้คือ

1. สตริงซิกเนเจอร์ (String signatures) จะสนใจส่วนของข้อมูลในแพ็กเก็ต โดยหาส่วนของสตริงที่อาจบ่งถึงว่าเป็นการบุกรุกได้ ตัวอย่างของสตริงซิกเนเจอร์สำหรับระบบยูนิคซ์ เช่น “cat”++”>/.rhosts” ซึ่งถ้าเจอในแพ็กเก็ตใด ก็อาจสรุปได้ว่าเป็นแพ็กเก็ตของการโจมตี
2. พอร์ตซิกเนเจอร์ (Port signatures) ตรวจสอบการเชื่อมต่อไปยังพอร์ตที่นิยมใช้ในการโจมตี ตัวอย่างของพอร์ตเหล่านี้ได้แก่ telnet (ทีซีพี พอร์ต 23) FTP (ทีซีพี พอร์ต 21/20) SUNRPC (ทีซีพี/ยูดีพี พอร์ต 111) และ IMAP (ทีซีพี พอร์ต 143) ซึ่งถ้าพอร์ตเหล่านี้ไม่ได้ถูกใช้โดยเซิร์ฟเวอร์แล้ว แพ็กเก็ตที่เข้ามายังพอร์ตเหล่านี้ก็จะจัดได้ว่าเป็นที่น่าสงสัยที่จะเป็นการบุกรุก
3. เฮดเดอร์ซิกเนเจอร์ (Header signatures) ตรวจสอบส่วนหัวของแพ็กเก็ตว่ามีส่วนประกอบที่ผิดปกติ ไม่สมเหตุสมผลหรือไม่ ตัวอย่างที่รู้จักกันดีที่สุดคือ Winnuke หรืออีกตัวอย่างก็คือ แพ็กเก็ตที่มีทั้งแฟล็ก SYN และ FIN ตั้งไว้ซึ่งหมายความว่าผู้ส่งต้องการที่จะเริ่มและหยุดการติดต่อในเวลาเดียวกัน

ข้อดีของ Network-base IDS ก็คือ สามารถตรวจพบการบุกรุกหรือการละเมิดความปลอดภัยและทำการป้องกัน ก่อนที่จะเกิดการโจมตีได้ โดยสามารถทำการตรวจสอบได้ตั้งแต่ที่แพ็กเก็ตยังเข้ามาไม่ถึงระบบ และสามารถดูถึงเจตนาที่มุ่งร้ายได้

ตัวอย่างโปรแกรมทางด้าน NIDS ก็คือ โปรแกรม snort ซึ่งเป็นโปรแกรมที่นิยมใช้กันมากเนื่องจากเป็นโปรแกรม opensource และสามารถประยุกต์ใช้เป็นโปรแกรม IPS ได้ คือสามารถป้องกันได้โดยไม่จำเป็นต้องตรวจสอบอย่างเดียวนั่น

2.4.2.1 Snort และ Snort-Inline

Snort เป็นเครื่องมือที่ใช้ตรวจจับการบุกรุกทางเครือข่าย (network intrusion detection) โดยการทำงานของ Snort จะใช้ไลบรารี (library) พื้นฐานชื่อ libpcap ซึ่งใช้กันโดยทั่วไปในบรรดา network sniffer และ network analyzerทั้งหลาย สำหรับ Snort นั้นสามารถทำ protocol analysis, content searching/matching, ตรวจจับการบุกรุกและ probe เช่น buffer overflow, stealth port scan, CGI attack, SMB probe, OS Fingerprint และอื่นๆ

นอกจากนี้โปรแกรม Snort ยังมีคุณสมบัติในการทำ real-time alerting อีกด้วย นอกเหนือจากการเก็บล็อกไปที่ syslog หรือเก็บแยกไฟล์ต่างหาก และยังสามารถ alert ผ่าน winpopup ผ่านทาง Samba's client ได้อีกด้วย

ปัญหาที่สำคัญที่สุดของ IDS ก็คือ โดยส่วนใหญ่แล้ว IDS ไม่สามารถป้องกันการบุกรุกในลักษณะ "Real Time" ได้ เช่นการจู่โจมแบบ DoS (Denial of Services) หรือ DDoS (Distributed Denial of Services) Attack จากปัญหานี้ จึงมีคนคิดค้นเทคโนโลยีใหม่ขึ้นมา เรียกว่า "IPS" (Intrusion Prevention System) ซึ่งเราอาจจะให้คำจำกัดความง่ายๆ ว่า "IPS" = "IDS" + "Active Response" หมายถึง IPS สามารถป้องกันการบุกรุกและหยุดการบุกรุกได้ทันที

IPS นั้น แบ่งออกเป็น 2 Generations ใน Generation แรกนั้น การหยุดการบุกรุกทำได้โดยการส่งสัญญาณ TCP Reset จัดการกับ TCP Session ที่ IPS คิดว่าเป็นการบุกรุกหรืออาจจะเข้าไปเปลี่ยนแปลงแก้ไข Rules Based ใน Firewall แบบอัตโนมัติ ซึ่งบางครั้งอาจเกิดความผิดพลาดได้ สำหรับ IPS ใน Generation ที่ 2 นั้น ได้มีการปรับปรุงให้เป็นลักษณะ "Intelligent Network Element" ซึ่งสามารถรู้จักเทคนิคของพวก Hacker เช่น IDS Evasion หรือ Anomaly IP Packet โดยมีการวิเคราะห์ IP Packet Traffic อย่างละเอียด

IPS รุ่นใหม่ที่มีความฉลาดมากขึ้นนั้น มีการใช้เทคโนโลยีขั้นสูงในการวิเคราะห์ข้อมูล เช่น Neural Network และ Fuzzy Logic ซึ่งจะทำให้ลดปัญหา Fault Positive และ Fault Negative ลงได้อย่างมาก ตลอดจน เนื่องจาก IPS ใช้หลักการเปรียบเทียบข้อมูล แปลกปลอมจากการปรับแต่ง IP Packet โดยใช้มาตรฐาน RFC ของ IETF ในการตัดสินใจ ทำให้ IPS บางรุ่น สามารถป้องกันการโจมตีแบบ DoS หรือ DDoS Attack ได้ด้วย

ปัญหาของ IPS ก็มีเหมือนกัน ที่ชัดเจนเลยก็คือ ยังมีราคาค่อนข้างแพงมาก เมื่อเปรียบเทียบกับ IDS ส่วนใหญ่แล้ว IPS ที่มาใน ลักษณะของ Network Appliance นั้นจะมีราคาในหลักล้านบาทขึ้นไป และ การทำงานของ IPS จะใช้หลักการที่เรียกว่า "Inline" หรือ บางตำราเรียกว่า "Gateway IDS" คือ มีการนำ IPS ไปกั้นกลางระหว่าง ต้นทาง กับ ปลายทาง ของเส้นทางการส่งข้อมูล โดยไม่ต้องมีการกำหนด IP address ให้กับตัว IPS ปัญหาก็คือ หากตัว IPS เกิดเสีย ถ้า IPS ไม่สามารถ Bypass ตัวเองได้ ก็จะทำให้เกิดปัญหาในการรับส่งข้อมูลระหว่างต้นทางกับปลายทาง ตลอดจนถ้า IPS ตัดสินใจผิด การ "Block" IP Packet ที่ IPS คิดว่าเป็นการบุกรุก แต่จริงๆ แล้วเป็น Traffic การใช้งานธรรมดา ก็จะทำให้เกิดปัญหากับผู้ใช้งานทั่วไปได้เช่นกัน

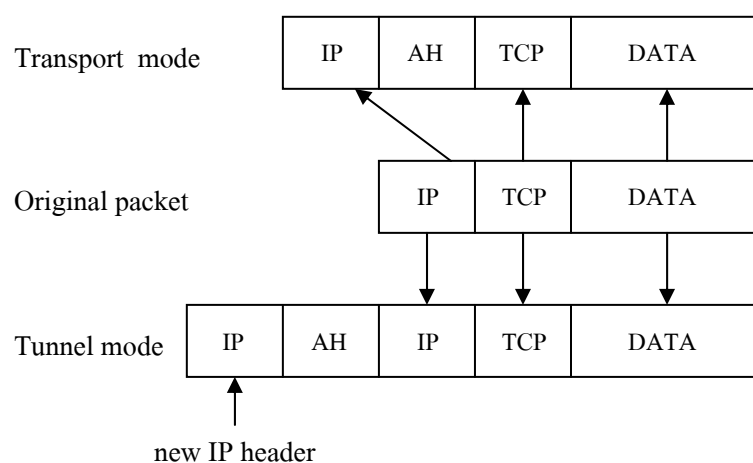
ต่อมาจึงมีการพัฒนาโปรแกรม Snort โดยมีการพยายามนำ Snort Engine มาแก้ไขให้เพิ่มความสามารถป้องกัน (drop) การโจมตีของบุกรุกได้ โดยไม่เพียงแต่แจ้งเตือน (alert) อย่างเดียว โดยนำ Snort Engine, iptables มาทำงานร่วมกันโดยดักจับ Packet ที่ Layer2 (Data-Link Layer) ซึ่งมีลักษณะการทำงานแบบ Bridge และตั้งชื่อใหม่ว่า "Snort Inline" ซึ่งมีคุณสมบัติเป็น IPS ที่สามารถป้องกันการโจมตีของ Hacker อย่างได้ผลและมีประสิทธิภาพ

2.5 Internet Protocol Security (IPsec)

IPsec เป็นส่วนเพิ่มขยายของ Internet Protocol (IP) ในชุดโพรโตคอล TCP/IP พัฒนาเพื่อเป็นส่วนหนึ่งของมาตรฐานของ IPv6 ซึ่งเป็นโพรโตคอลที่พัฒนาเพื่อใช้แทน IPv4 ที่ใช้ในปัจจุบันและกำหนดหมายเลข RFC เป็น RFC2401

IPsec ใช้โพรโตคอล 2 ชุดคือ Authentication Header (AH) และ Encapsulated Security Payload (ESP) เพื่อรองรับการพิสูจน์ตัวตน (Authentication) การรักษาความถูกต้องของข้อมูล (Integrity) และการรักษาความลับ (Confidentiality) ในระดับชั้นของ IP

โดยการใช้งานสามารถเลือกใช้ได้สองรูปแบบตามรูป



รูปที่ 2.3 รูปแบบการใช้งาน IPsec

- Tunnel mode เป็นการนำส่วนแพ็กเก็ตเดิมทั้งหมดมาครอบด้วย IP โพรโตคอลชุดใหม่ที่เป็นไปตามชุดโพรโตคอล IPsec สังเกตได้จากมีการเพิ่มเฮดเดอร์ IP และ AH เข้าไปข้างหน้าแพ็กเก็ตชุดเดิม
- Transport mode นำเฉพาะข้อมูลของโพรโตคอล IP ซึ่งจะประกอบด้วยข้อมูลของชั้น Transport (TCP หรือ UDP) และชั้นแอปพลิเคชัน โดยเพิ่มโพรโตคอล AH และเพิ่มข้อมูลใน IP เดิมให้เหมาะสมตามมาตรฐาน IPsec

การรักษาความถูกต้องของข้อมูลของ IP คาตาแกรม (IP Datagram) ในชุดโพรโตคอล IPsec ใช้ Hash Message Authentication Codes หรือ HMAC ด้วยฟังก์ชันแฮชเช่น MD5 หรือ SHA-1 ทุกครั้งที่มีการส่งแพ็กเก็ตจะมีการสร้าง HMAC และใช้การเข้ารหัสไปด้วยทุกครั้ง เพื่อให้ปลายทางสามารถตรวจสอบได้ตามหลักการลายเซ็นดิจิทัลว่าต้นทางเป็นผู้ส่งแพ็กเก็ตนั้นมาจริง

ส่วนการรักษาความลับของข้อมูลนั้น จะใช้การเข้ารหัส IP คาตาแกรมด้วยวิธีการเข้ารหัสด้วยกุญแจสมมาตร ด้วยวิธีการมาตรฐานที่เป็นรู้จักกันดีเช่น 3DES AES หรือ Blowfish เป็นต้น

ปัญหาหนึ่งของ IPsec คือการส่งกุญแจที่ใช้ในการเข้ารหัสไปกับแพ็กเก็ต ซึ่งจัดว่าไม่ปลอดภัย นอกจากนี้การแลกเปลี่ยนกุญแจนำไปสู่ปัญหาของการดูแลระบบที่ใช้ IPsec เพราะทั้งระบบต้องสนับสนุนการใช้งานโพรโตคอล IPsec เดียวกัน จะทำอย่างไรให้สามารถส่งกุญแจในการเข้ารหัสไปกับแพ็กเก็ตถ้าไม่มีการเข้ารหัสแพ็กเก็ตแต่อย่างใด เพื่อแก้ปัญหาจึงได้พัฒนาโพรโตคอลในการแลกเปลี่ยนกุญแจหรือ Internet Key Exchange Protocol (IKE)

IKE จะทำการพิสูจน์ตัวตนของปลายทางก่อนการสื่อสาร ในขั้นตอนถัดมาจึงสามารถแลกเปลี่ยนและตกลง Security Association และกุญแจในการเข้ารหัสได้ด้วยวิธีการแลกเปลี่ยนกุญแจตามวิธีการแลกเปลี่ยนกุญแจด้วยการใช้กุญแจสาธารณะเช่น Diffie-Hellmann เป็นต้น ซึ่งชุดโพรโตคอล IKE จะตรวจสอบกุญแจที่ใช้ในการเข้ารหัสระหว่างการติดต่อสื่อสารเป็นระยะตลอดการสื่อสารข้อมูลที่เกิดขึ้นแต่ละครั้ง

ชุดโพรโตคอล IPsec ประกอบด้วยโพรโตคอลหลักสองโพรโตคอลคือ Authentication Header (AH) และ Encapsulated Security Payload (ESP)

AH หรือ Authentication Header ทำหน้าที่รักษาความถูกต้องของ IP คาตาแกรม โดยการคำนวณ HMAC กับทุก IP คาตาแกรมตามรูป

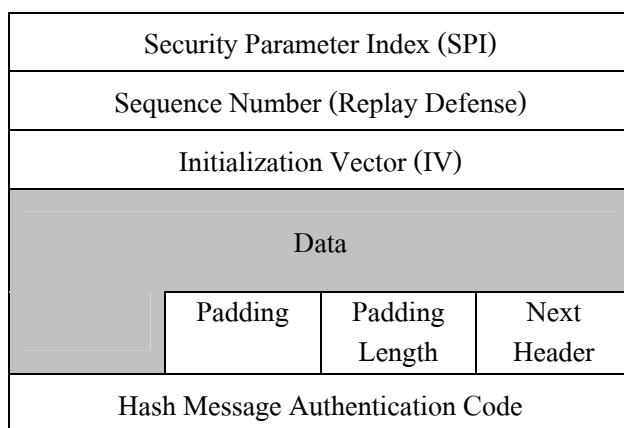
Next Header	Payload Length	Reserved
Security Parameter Index (SPI)		
Sequence Number (Replay Defense)		
Hash Message Authentication Code		

รูปที่ 2.4 Authentication Header

เฮดเดอร์ของ AH มีขนาด 24 ไบต์ อธิบายได้ดังนี้

- Next Header ใช้เพื่อบอกให้ทราบว่ากำลังใช้รูปแบบใดในการใช้งาน IPsec ระหว่าง Tunnel mode ค่าจะเป็น 4 ส่วน Transport mode ค่าจะเป็น 6
- Payload length บอกความยาวของข้อมูลที่ต่อท้ายเฮดเดอร์ ตามด้วย Reserved จำนวน 2 ไบต์
- Security Parameter Index (SPI) กำหนด Security Association สำหรับใช้ในการถอดรหัสแพ็กเก็ตเมื่อถึงปลายทาง
- Sequence Number ขนาด 32 บิตใช้บอกลำดับของแพ็กเก็ต
- Hash Message Authentication Code (HMAC) เป็นค่าที่เกิดจากฟังก์ชันแฮชเช่น MD5 หรือ SHA-1 เป็นต้น

ESP หรือ Encapsulated Security Payload ใช้สำหรับรักษาความถูกต้องของแพ็กเก็ตโดยใช้ HMAC และการเข้ารหัสรวมด้วย



รูปที่ 2.5 Encapsulated Security Payload

- Security Parameter Index (SPI) กำหนด Security Association (SA) ระบุ ESP ที่สอดคล้องกัน
- Sequence Number ระบุลำดับของแพ็กเก็ต
- Initialization Vector (IV) ใช้ในกระบวนการเข้ารหัสข้อมูล ป้องกันไม่ให้สองแพ็กเก็ตมีการเข้ารหัสที่ซ้ำกันเกิดขึ้น
- Data คือข้อมูลที่เข้ารหัส
- Padding เป็นการเติม Data เพื่อให้ครบจำนวนไบต์ที่เข้ารหัสได้
- Padding Length บอกความยาวของ Padding ที่เพิ่ม
- Next Header กำหนดเฮดเดอร์ถัดไป
- HMAC ค่าที่เกิดจากฟังก์ชันแฮชขนาด 96 บิต

2.6 Forensics

2.6.1 Computer Forensics

2.6.1.1 พื้นฐานสำคัญที่ใช้ในการ ตรวจสอบการละเมิดสิทธิ์ และหาข้อมูล

start-up

ตามพฤติกรรมของผู้บุกรุก หลังจากที่เราเข้ามาในเครื่องเราได้แล้ว ผู้บุกรุกมักจะทิ้งช่องทางเอาไว้เพื่อที่จะได้สามารถกลับเข้ามาในเครื่องเราได้อีกครั้ง และตามปกตินั้น ก็จะทำการลงโปรแกรมจะพวก rootkit หรือ อาจจะมีชุดคำสั่งที่เอาไปใส่ไว้เพื่อให้ทำงานทุกครั้งที่เปิดเครื่องขึ้นมา

โปรเซสแรกที่จะทำงานหลังจาก boot ก็คือ init โดยปกติแล้วสำหรับ ลินุกซ์นั้น init จะไปทำการอ่านค่าต่างๆ ที่ตั้งเอาไว้ที่ไฟล์ /etc/inittab ก่อน ซึ่งภายในไฟล์ก็จะกำหนดค่าที่ใช้ในการเริ่มต้นโปรเซส หลังจาก boot ระบบ และค่า ระดับการทำงานต่างๆเอาไว้ ซึ่งขึ้นมาจากไฟล์ /etc/rc*.d

สำหรับ /etc/rcS.d นั้นภายในโฟลเดอร์ จะเก็บไฟล์ที่จะให้ทำงานทุกครั้งที่เปิดเครื่องไม่ว่าจะกำหนดค่าให้ทำงานที่ระดับใดก็ตาม โดยที่ไฟล์ที่กำหนดให้รันเมื่อเปิดเครื่องทุกครั้งจะขึ้นต้นด้วย S ส่วน ที่จะให้ทำทุกครั้งที่เวลาปิดเครื่อง ต้องขึ้นต้นด้วย K และ ที่ระดับต่างๆก็จะมีการกำหนดค่าให้เริ่มทำงานโปรแกรมตามที่กำหนดอีกที่ อย่างเช่นใน folder /etc/rc2.d/ ก็จะเก็บไฟล์ที่จะทำงานเมื่อระบบเริ่มต้นที่ กำหนดให้ใช้ระดับ 2 โดยการตั้งชื่อนั้นก็จะเหมือนกันกับ rcS.d

โดยปกติแล้วไฟล์ที่ทำงานจริงๆจะเก็บเอาไว้ที่ /etc/init.d/ แต่ว่าจะทำ symbolic link เข้าไปที่ rc*.d ต่างๆแทน

Kernel Modules

จะเตรียมฟังก์ชันการทำงานต่างๆ เอาไว้ที่ kernel และมักจะถูกผู้บูทกรนำไปใช้ในการควบคุมระบบของเรา โดย kernel module สามารถโหลดในตอน เริ่มเปิดเครื่องโดยใช้คำสั่ง insmod หรือ modprobe หรืออีกวิธีก็คือการใช้ kernald ซึ่งคำสั่งหรือ modules ที่จะถูกโหลดเข้ามาตอนเปิดเครื่องนั้นโดยปกติแล้วจะถูกเก็บเอาไว้ที่ โฟลเดอร์ /lib/module/ชื่อkernel/ โดยที่ไฟล์ modules.dep จะเก็บ ว่าโมดูลใดขึ้นต่อกันบ้าง และโมดูลใดที่ต้องโหลดเข้ามาเพิ่มอีก

Data hiding

เมื่อผู้บูทกรเข้ามาพัวพันระบบ เป็นเรื่องปกติที่จะต้องทำการสร้างไฟล์ใหม่ขึ้นมาบนระบบ แต่ว่าผู้บูทกรนั้นก็ไม่ต้องการที่จะทำให้คนอื่นสามารถพบเห็นได้ง่ายๆ จึงต้องมีการใช้เทคนิคต่างๆ เพื่อช่วยในการซ่อนไฟล์

วิธีการ 2 วิธีที่ผู้บูทกรมักใช้เป็นประจำก็คือ

1. ทำการซ่อนไฟล์ เอาไว้ในที่ ที่ผู้ใช้ปกตินั้นไม่ค่อยสนใจ และไม่สังเกต ซึ่งในระบบยูนิกซ์ นั้นที่ๆหนึ่งที่มีคุณสมบัติดังนี้ก็คือ ที่โฟลเดอร์ /dev/ ซึ่งเป็นโฟลเดอร์ที่เก็บไฟล์ไว้มากมาย และหลากหลายชนิด และมีการสร้างหรือลบอยู่เกือบตลอดเวลา

2. คือเทคนิค ที่ใช้การตั้งชื่อด้วย "." ซึ่งปกติแล้วไฟล์ที่มีการตั้งชื่อด้วย "." นั้นจะไม่สามารถมองเห็นได้ถ้ามีการใช้คำสั่ง ls แบบปกติ หรืออีกทางก็คือการตั้งชื่อไฟล์ด้วยช่องว่าง

Inode

คือ โครงสร้างข้อมูล ของระบบไฟล์ ที่จะเก็บข้อมูลต่างๆไปของไฟล์ ไดรেকทอรี และอื่นๆ ซึ่งจะต้องประกอบด้วยส่วนต่างๆอย่างน้อยดังนี้

- ความยาวของไฟล์ที่มีขนาดเป็น ไบต์
- Device ID คือค่าที่ระบุ ว่า อุปกรณ์ตัวไหนที่เป็นตัวเก็บไฟล์นั้นอยู่
- User ID
- Group ID
- หมายเลข inode เอาไว้ใช้ในการจำแนกแยกแยะ ไฟล์ ภายในระบบไฟล์ เมื่อไหร่ก็ตามที่โปรแกรม อ้างถึงไฟล์โดยชื่อ ระบบจะใช้ชื่อของไฟล์เพื่อไปดูค่า inode ที่เกี่ยวข้องกับไฟล์นั้น ซึ่งจะให้ข้อมูลที่ต้องการเกี่ยวกับไฟล์
- file mode เอาไว้พิจารณาว่าผู้ใช้สามารถใช้อ่าน เขียน หรือ execute ได้
- Timestamp สำหรับไฟล์ชนิดที่เป็น ext3 นั้นจะเก็บเวลาทั้งหมด 4 ชนิดคือ Modified time, Accessed, changed และ delete time ค่าที่เก็บจะเป็นค่าครั้งสุดท้ายของสิ่งนั้นๆ

- modified time เป็นเวลาครั้งสุดท้ายที่ไฟล์นั้นโดนแก้ไข ถ้ามีการเพิ่มหรือลดขนาดของไฟล์ ค่าเวลานี้ก็จะโดนแก้ไข
 - accessed time คือเวลาครั้งสุดท้ายที่ ข้อมูลของไฟล์ถูกเข้าถึง อย่างเช่น ไฟล์ถูกอ่านด้วยคำสั่ง cat
 - change time เป็นเวลาครั้งสุดท้าย ที่มีการเปลี่ยนแปลง inode อย่างเช่นมีการเปลี่ยนแปลง permission หรือ ขนาดของไฟล์
 - delete time คือ เวลาครั้งสุดท้ายที่ไฟล์โดนลบ หรือ กลายเป็น 0 ถ้ามันไม่ได้โดนลบ
- reference count เพื่อบอกว่ามี hard link เท่าไหร่

inode สามารถใช้อ้างถึงโครงสร้างข้อมูลและ device block ที่มันจัดการอยู่ (สำหรับไฟล์ทั่วๆ ไปนั้น block ถูกสร้างขึ้นเป็น ตัวของไฟล์)

inode โดยปกติแล้วมันจะถูกอ้างถึง inode บน block device ซึ่งจัดการกับไฟล์ทั่วๆ ไป , directory และ symbolic link ซึ่งมีส่วนสำคัญในการกู้คืนไฟล์ที่เสียหายในระบบ

Delete File

สำหรับระบบเดิมอย่างเช่น ext2 นั้นเมื่อผู้ใช้ทำการลบไฟล์ ค่า inode จะยังถูกเก็บอยู่ เพียงแต่มีการตั้งค่าให้เป็นพื้นที่ ที่ไม่ได้ใช้เท่านั้นทำให้สามารถกู้คืนได้เมื่อมีการลบไป

ไฟล์ประเภท ext3 นั้นถ้ามีการลบจะทำการ เคลียร์ค่า inode และ block ทั้งไปทั้งหมดทำให้ไม่สามารถกู้คืนกลับมาได้

Process

โดยปกติเราจะใช้คำสั่ง ps แล้วตามด้วย option ต่างๆ อย่างเช่น ps aux เพื่อใช้ในการตรวจสอบว่า มี process ใดบ้างที่กำลังทำงานอยู่บนระบบขณะนั้น เพื่อที่จะได้ตรวจสอบหาว่า มี process แปลกๆ จาก user คนไหนบ้าง แต่ว่า การใช้คำสั่งนี้ก็ยังไม่น่าเชื่อถือมากเท่าที่ควรเพราะว่า ผู้บุกรุก สามารถทำให้โปรแกรมหลบซ่อนจากคำสั่ง ps ได้ โดยที่เราสามารถเข้าไปตรวจสอบที่ /proc ได้ เพราะว่าคำสั่ง ps จะเป็นการไปดึงข้อมูลจาก /proc เพื่อเอาออกมาแสดง ดังนั้นเราควรตรวจสอบว่า จำนวน process ใน /proc มีจำนวนเท่ากับ คำสั่ง ps aux หรือไม่

การจัดเก็บข้อมูลใน /proc

เก็บข้อมูลเกี่ยวกับ process ตามหมายเลขที่กำหนดไว้ เช่น /proc/1234 ภายใน directory นี้ จะเก็บข้อมูลเกี่ยวกับ process ที่มีหมายเลข process เป็น 1234 ไว้ ซึ่งภายในมีรายละเอียดดังนี้

1. ไฟล์ cmdline จะเก็บคำสั่งที่ process นั้นประมวลผล
2. ไฟล์ environ เก็บค่าตัวแปรสภาพแวดล้อมของ process นั้น
3. ไคลเรททอรี fd เก็บ symbolic link ของ file descriptor ของไฟล์ที่ process นั้นเรียกทำงาน
4. cwd Symbolic link เป็นลิงค์ที่ชี้ไปยังไคลเรททอรีที่ process ทำงานอยู่
5. exe Symbolic link เป็นลิงค์ที่ชี้ไปยัง process ที่กำลังประมวลผลอยู่
6. ไฟล์ maps เก็บส่วน memory map ของ process ซึ่งประกอบด้วยช่วงตำแหน่ง permission หรือ offset เป็นต้น
7. root Symbolic link เป็นลิงค์ที่ชี้ไปยัง root directory
8. ไฟล์ statm เก็บข้อมูลการใช้งานหน่วยความจำของ process
9. ไฟล์ stat เก็บข้อมูลรายละเอียดเกี่ยวกับ process ซึ่งมีรายละเอียดมากที่สุด
10. ไฟล์ status เก็บข้อมูลเช่นเดียวกับ stat แต่จะเข้าใจง่ายกว่า

Port

การตรวจสอบว่าเราเปิด port อะไรอยู่บ้างนั้น ปกติแล้วเราใช้คำสั่ง netstat เพื่อตรวจสอบ ดูแต่บ่อยครั้งก็โดนซ่อนเช่นกัน โดยผู้บุกรุกอาจจะทำการเปิด port บาง port เพื่อเป็น backdoor เอาไว้และซ่อนจากการใช้คำสั่ง netstat ซึ่งเราก็อาจจะตรวจสอบได้โดยการใช้โปรแกรม scan port เพื่อตรวจสอบ port ที่เครื่องเปิดเอาไว้ได้

Suid,Sgid

คือไฟล์ที่มีการเซตค่า sticky bit เอาไว้โดยที่ เมื่อไฟล์ใดที่มีการเซตค่านี้ไว้ เมื่อมี ผู้ใช้คน อื่นที่ไม่ใช่เจ้าของไฟล์มาใช้งานไฟล์นั้น ก็จะได้สิทธิ์ เท่ากับ uid ของเจ้าของไฟล์ (โดยปกติ เมื่อ เราทำการเรียกใช้โปรแกรม อะไรก็ตาม process ที่ถูกเรียกขึ้นมาก็จะได้ euid ซึ่งมีค่าเท่ากับ uid ของ ผู้เรียกไฟล์นั้น แต่เมื่อ มีการเซตค่า sticky bit เข้าไป euid จะมีค่าเท่ากับ uid ของเจ้าของไฟล์) จาก ความสามารถดังกล่าว อาจจะทำให้ผู้บุกรุกนำไฟล์ของ root ที่มีการเซตค่า sticky bit นี้ไปใช้ในการ exploit ระบบ ซึ่งเราต้องคอยตรวจสอบการเปลี่ยนแปลงของไฟล์เหล่านี้้อย่างสม่ำเสมอ

ไฟล์ /etc/passwd , /etc/shadow

ทั้ง 2 ไฟล์นี้มีความสำคัญมากและควรตรวจสอบอย่างสม่ำเสมอโดยที่ ต้องคอยดูว่ามี user เพิ่มขึ้นมาหรือมีการเปลี่ยน user id ให้มีความสามารถสูงขึ้นหรือไม่

/etc/init.d , /etc/rc*.d

ทั้ง 2 ไคเรกทอรีนี้ จะเก็บไฟล์โปรแกรมที่จะเริ่มทำงานเมื่อเรา start เครื่อง โดยที่ผู้บุกรุกอาจจะเอาโปรแกรมไปซ่อนไว้ที่ ไคเรกทอรีเหล่านี้ได้

crontab

คือโปรแกรมที่ใช้ตั้งเวลาการทำงานของโปรแกรมต่างๆ โดย ผู้บุกรุกอาจจะเข้าไปตั้งค่าเหล่านี้ได้เรียกให้บางโปรแกรมทำงานตามเวลาที่กำหนด

2.6.2 Network Forensics

สำหรับ การสืบหาหลักฐานทางเครือข่ายจะเป็นการหาคำตอบของคำถามต่อไปนี้

- เป็นการละเมิดสิทธิ์ หรือเป็นเพียงแค่การแจ้งเตือนที่ผิดพลาด
- ใครเป็นคนละเมิดสิทธิ์หรือใครที่เข้ามาพัวพันด้วย
- การละเมิดสิทธิ์เกิดขึ้นเมื่อเวลาใด
- อะไรคือ traffic ระหว่าง เครื่องผู้บุกรุก และเครื่องที่โดนบุกรุก
- เป็นเวลานานเท่าใดที่ผู้บุกรุกอยู่ในเครื่องเป้าหมาย
- รูปแบบของการกระทำการละเมิดสิทธิ์ เป็นไปในรูปแบบใด
- คำสั่งอะไรที่ ผู้ละเมิดสิทธิ์ใช้
- ผู้บุกรุกได้ทำการติดตั้งโปรแกรมประเภท rootkit หรือ backdoor ไว้หรือไม่
- อะไรเป็นสัญญาณที่บ่งบอกถึงการละเมิดสิทธิ์เริ่มแรก

Network Traffic

เมื่อมีเครื่อง 2 เครื่องที่ทำการแลกเปลี่ยนข้อมูลกันผ่านทางเครือข่าย ก็จะต้องมีการสื่อสารกันโดยผ่านทางสิ่งที่เรียกว่า โปรโตคอล เพื่อที่จะได้กำหนดค่าต่างๆของ แพ็กเก็ตที่จะแลกเปลี่ยนกันนั้น เป็นไปในรูปแบบเดียวกัน และสื่อสารกันได้อย่างเข้าใจ โดยปกติแล้ว โปรโตคอลที่นิยมใช้กันอย่างแพร่หลาย ก็คือ TCP/IP

TCP/IP ประกอบด้วย 2 โปรโตคอล คือ IP ซึ่งจะเป็นตัวที่ใช้กำหนดว่า แพ็กเก็ตนั้นมาจากที่ไหน และจะส่งไปที่ไหน ส่วน TCP นั้น เป็นตัวที่กำหนดเพื่อให้มั่นใจได้ว่าข้อมูลที่ได้รับทางปลายทางนั้น มีความถูกต้องตามลำดับ โดยที่ทั้ง 2 โปรโตคอลที่กล่าวมานั้นกระทำโดยการเพิ่มส่วนของ เฮดเดอร์ เข้าไปที่ข้อมูลที่ได้รับมาจากโปรแกรมแอปพลิเคชันต่างๆ

การที่จะวิเคราะห์ว่าข้อมูลที่ส่งมานั้นถูกต้องหรือไม่ ก็จำเป็นจะต้องเข้าใจ ว่า ผู้บุกรุกนั้นจะกระทำอย่างไรต่อ เฮดเดอร์ และเข้าใจ ส่วนต่างๆของเฮดเดอร์ว่ามีอะไรบ้าง

ตัวอย่างการตรวจสอบจาก header ของ โปรโตคอล

การตั้งค่าให้มีการ fragmentation ที่โปรโตคอล IP เพื่อหลีกเลี่ยงการตรวจจับของ โปรแกรมที่ทำหน้าที่ป้องกันต่างๆ เพราะฉะนั้น แพ็กเก็ตที่มีขนาดเล็กลงมาก ก็ถือว่าเป็น แพ็กเก็ตที่น่าสงสัย ซึ่งปกติแล้วขนาดของแพ็กเก็ต ไม่น่าจะต่ำกว่าครึ่งหนึ่งของขนาดใหญ่ที่สุดที่รับได้

การตรวจสอบค่า ttl ของแพ็กเก็ตเพื่อตรวจสอบว่าแพ็กเก็ตนั้นถูกส่งมาไกลเพียงใดและ น่าจะเป็น เครื่อง ปฏิบัติการชนิดไหน โดยปกติ ระบบปฏิบัติการวินโดวส์ จะใช้ค่า ttl เริ่มต้นเป็น 255 ส่วนระบบปฏิบัติการจำพวก ยูนิกซ์ จะใช้ค่า ttl เริ่มต้นเป็น 128

ค่า sequence ใช้ในการพิจารณาว่ามีการสร้าง แพ็กเก็ตของเซสชัน นั้นใหม่หรือไม่

ค่า Header length ของโปรโตคอล ทีซีพี นั้น ปกติแล้วจะถูกส่งวนเอาไว้เพื่อใช้ในอนาคต แต่ว่า บ่อยครั้งที่ถูกผู้บุกรุกนำมาใช้ในการ ติดต่อสื่อสารอย่างซ่อนเร้นกันระหว่างเครื่อง ที่โดน บุกกรุก กับเครื่องของผู้บุกรุก อาจจะเป็นช่องทางที่ถูกติดตั้งไว้โดย โปรแกรม รุกคิด ต่างๆ

การจำแนก การสแกนพอร์ต

สแกนพอร์ต เป็นวิธีที่ใช้ในการตรวจสอบว่า เครื่องปลายทางนั้นเปิด พอร์ตอะไรไว้บ้าง ซึ่งมี เทคนิคมากมายในการใช้ เพื่อ สแกนพอร์ต

ตัวอย่างที่ใช้ในการ สแกนพอร์ต

SYN scan: ผู้บุกรุกสามารถตรวจสอบ พอร์ตที่เปิดอยู่ด้วยการส่ง SYN แพ็กเก็ต เข้าไปยัง พอร์ตต่างๆ ถ้ามีการเปิดพอร์ตนั้นอยู่ ก็จะได้รับ SYN-ACK ตอบกลับมา ส่วน พอร์ตที่ปิดก็จะส่ง RST มาแทน ถ้าพอร์ตเปิด ผู้บุกรุกก็จะทำการส่ง RST เพื่อยกเลิกการติดต่อ

Connect scan: ผู้บุกรุกจะใช้การเชื่อมต่อ แบบสมบูรณ์เพื่อตรวจสอบ พอร์ตที่เปิดอยู่

Fin scan: เป็นการ ใช้ fin flag เพื่อตรวจสอบพอร์ตที่เปิดอยู่ โดยปกติไฟร์วอลล์บางชนิด จะไม่ได้ทำการปิดกั้น Fin แพ็กเก็ต ถ้าพอร์ตปิดมันจะส่ง RST กลับไป แต่ถ้าพอร์ตนั้นเปิดอยู่ เครื่องปลายทางก็จะละเอียดต่อ แพ็กเก็ต Fin นั้นและไม่ตอบอะไรกลับมา

Ack scan: ใช้เพื่อค้นหา พอร์ตที่โดนตรวจสอบโดยไฟร์วอลล์ ไฟร์วอลล์บางตัวในอดีต ไม่ได้ทำการปิดกั้นแพ็กเก็ต Ack ซึ่งทำให้สามารถใช้ในการแยกความแตกต่างระหว่างพอร์ตที่ โดนตรวจสอบ กับไม่โดนได้ โดยที่ถ้าเป็น พอร์ตที่เปิด หรือ ปิดทั่วไป ยังตอบ RST กลับมา แต่ ถ้าเป็น พอร์ตที่โดนกันโดยไฟร์วอลล์ จะไม่ส่งอะไรกลับมา ซึ่งอาจจะเป็น ไฟร์วอลล์ที่ไม่ใช่แบบ stateful

Passive Fingerprint

passive fingerprint เป็นวิธีที่ใช้เพื่อหาข้อมูลของเครื่องที่เราติดต่อกับ โดยที่มีความเสี่ยงน้อยกว่าที่ผู้โดนตรวจสอบจะรู้ตัว โดยสามารถตรวจสอบ ระบบปฏิบัติการ service หรือ โปรแกรม ที่เครื่องปลายทางนั้นๆ ใช้อยู่ โดยใช้เพียงแค่การ ดักจับแพ็กเก็ตเท่านั้น

โดยปกติแล้ว fingerprint นั้นจะเป็นวิธี active ในการตรวจสอบข้อมูลของเครื่อง ปลายทาง อย่างเช่น การใช้โปรแกรม nmap เป็นต้น

ตัวอย่างของ TCP Passive Fingerprint

- IP Time-To-Live เป็นจำนวน hop ที่กำหนดไว้เพื่อจำกัดระยะจากต้นทางไปยังปลายทาง
- Window Size เป็นค่ากำหนดการไหลของข้อมูล ซึ่งจะแตกต่างกันตามระบบปฏิบัติการ
- DE บางระบบปฏิบัติการจะกำหนดเอาไว้ว่าไม่ให้มีการ แลกข้อมูล
- TOS การกำหนดว่าจะใช้ ชนิดไหน ขึ้นอยู่กับ ระบบปฏิบัติการ

จากด้านบนเป็นเพียงชนิดของข้อมูลจาก header ของแพ็กเก็ตที่นิยมนำมาใช้ในการพิจารณา และไม่ได้จำกัดว่าจะต้องใช้เพียงแค่ 4 ฟิลด์นี้เท่านั้น และผลที่ได้จากการพิจารณา ชนิดของระบบปฏิบัติการที่ได้มานั้นไม่อาจจะบอกได้ 100 เปอร์เซ็นต์ ว่าเป็นระบบปฏิบัติการนั้นจริงหรือไม่ ไม่มีสัญลักษณ์ใด(อย่างเดียว)ที่จะสามารถบอกได้อย่างแน่นอน แต่อย่างไรก็ตามการที่นำข้อมูลหลายๆ อย่างมารวมกันในการพิจารณา ก็สามารถเพิ่มความแม่นยำ ในการจำแนกได้

ตัวอย่างการวิเคราะห์ โดย พิจารณาจาก Icmp

โดยส่วนมากแล้ว icmp echo request จะแตกต่างกันในแต่ละระบบปฏิบัติการ โปรแกรมประเภท ping ที่ใช้กันทั่วไปใช้การส่ง ICMP echo request ซึ่งสามารถใช้แบ่งกันได้อย่างชัดเจนระหว่าง ตระกูลยูนิกซ์ และตระกูลวินโดวส์

ตัวอย่างที่ได้มาจากการวิเคราะห์

ICMP Echo Request Datagram Size: ในส่วนของระบบปฏิบัติการวินโดวส์ จะใช้ขนาดความยาวเท่ากับ 60 ไบต์ ส่วนทางด้านระบบปฏิบัติการประเภท ยูนิกซ์นั้นจะใช้ขนาดเท่ากับ 84 ไบต์

ICMP Echo Request Data Payload Content: ในส่วนของระบบปฏิบัติการวินโดวส์ จะส่งตัวอักษรเข้ามาใน ส่วนของ data payload ส่วนในระบบปฏิบัติการจำพวก ยูนิกซ์ นั้นจะส่งตัวเลข และอักขระพิเศษเข้ามาแทน

ICMP Echo Request Timestamp: ในผลของการ ping นั้น โดยปกติจะแสดงค่า RTT ซึ่งเป็นค่าเวลาที่คำนวณเวลาที่ใช้ไปกลับในการส่ง แพ็กเก็ต ในระบบปฏิบัติการจำพวก ยูนิกซ์ 8 ไบต์แรกของ data payload จะเป็นค่า timestamp ซึ่งช่วยเราในการหา RTT ส่วนในระบบปฏิบัติการ

จําพวงวินโดว์นั้นจะไม่มีการส่งข้อมูล timestamp มาด้วยข้อมูลจะเริ่มด้วยตัวอักษรเลข แต่ค่า timestamp นั้นจะเก็บไว้ที่ส่วนของ หน่วยความจําหลัก

ICMP Identification Number Used: ในระบบปฏิบัติการจําพวงวินโดว์นั้นใช้ค่าคงที่ 256,512 และ 768 สำหรับฟิลด์นี้ โดยค่าจะไม่มีการเปลี่ยน แต่ในระบบปฏิบัติการประเภท ยูนิกซ์ นั้น ค่าที่เก็บในฟิลด์นี้จะเป็นค่าที่ถูกตั้งขึ้นมาจาก หมายเลขของโปรเซสที่ ping ซึ่งจะเปลี่ยนแปลง ไม่คงที่

ICMP Sequence Number ในระบบปฏิบัติการจําพวงยูนิกซ์นั้นจะเริ่มด้วยค่า sequence number ด้วย ส่วนในระบบปฏิบัติการจําพวงวินโดว์นั้นจะให้ค่าเริ่มต้นเท่ากับค่าที่ใช้ครั้งล่าสุด บวกด้วย 256 และค่าจะกลับไปเริ่มที่ 0 เมื่อมีการ reboot ระบบ

ถึงแม้การตรวจสอบโดย icmp นั้นค่อนข้างจะแบ่งกันได้อย่างชัดเจนใน ตระกูลวินโดว์ และยูนิกซ์ แต่ว่าก็ยังมียุติการที่จะใช้หลบหลีกได้เช่นกัน อย่างเช่นการใช้ hping เพื่อ ping แบบที่ไม่ให้ ระบบปฏิบัติการเป็นตัวสร้างแพ็กเก็ตให้

ในการใช้ hping2 นั้นจะไม่มีการใส่ในส่วนของคุณข้อมูลเข้ามา ทำให้ขนาดของแพ็กเก็ตมีค่า เท่ากับ 28 ไบต์ และ ค่า ID number นั้นจะขึ้นอยู่กับหมายเลขของโปรเซสที่รันเหมือนกับ ระบบ ยูนิกซ์